Sri Lanka Institute of Information Technology



Group ID: 41

Northbridge Savings & Finance Network Security Upgrade

IT24300015 (Member 1)	Da Silva H.V.N. N
IT24101184 (Member 2)	Arundha H D J
IT24101551 (Member 3)	Kuyilini T
IT24100936 (Member 4)	De Silva K.H.Y.S. T

Packet Tracer File Link -:
https://drive.google.com/drive/folders/1fhOW_zLsws2sEP3MeJI_fAOdwmhwewft?usp=drive_link

Network Security | IE3122

B.Sc. (Hons) in Information Technology Specialized in Cyber Security

Year 3 Semester 1

2026

Contents

1. INTRODUCTION 5
   1.1 Purpose of the Report 5
   1.2 Scope 5
   1.3 Methodology 6
2. ORGANIZATION AND NETWORK SECURITY SCENARIO 7
   2.1 Northbridge Savings & Finance Overview 7
   2.2 Key Assets 7
   2.3 Current Network Architecture 8
3. EXISTING SECURITY WEAKNESSES 9
   3.1 Technical Weaknesses 9
   3.2 Physical Weaknesses 10
   3.3 Administrative Weaknesses 11
4. THREAT MODELING 12
   4.1 Ransomware via Unsegmented Branch Workstation (Threat 1: Member 1) 12
   4.2 Shared VPN Account Abuse (Threat 2: Member 1) 13
   4.3 Phishing/Credential Theft via Social Engineering (Threat 3: Member 2) 14
   4.4 Third-Party Payment Integration Compromise (Threat 4: Member 2) 15
   4.5 Unauthorized Database Access via Insider Misuse (Threat 5: Member 3) 16
   4.6 Data Loss/System Failure Due to Untested Backups (Threat 6: Member 3) 17
   4.7 Online Banking Portal Attack (SQLi/XSS) (Threat 7: Member 4) 18
   4.8 Unmanaged BYOD Endpoint Compromise (Threat 8: Member 4) 19
5. COMBINED LAYERED SECURITY PLAN 20
   5.1 Master Control List 20
   5.2 Control-to-Threat Mapping 22
   5.3 Function × Category Dual-Axis Table 24
   5.4 Control Minimization Justification 26
6. GROUP TECHNOLOGY EVALUATION 29
   6.1 VPN — Comparative Evaluation & Final Selection 29

6.2 AAA — Comparative Evaluation & Final Selection 30
6.3 Network Architecture — Comparative Evaluation & Final Selection 31
6.4 IDS/IPS — Comparative Evaluation & Final Selection 32
7. NETWORK SECURITY ARCHITECTURE 33
7.1 Architecture Overview 33
8. Network Hardening Configurations 34
8.1 Member 1 — Configuration 1: VLAN Segmentation on SW-Core (Plan-Linked) 34
Configuration Commands 34
8.2 Member 1 — Configuration 2: SSH Secure Management (Free Choice) 38
Configuration Commands 38
8.3 Member 2 — Configuration 1: Extended ACL on FW-PERIMETER (Plan-Linked) 41
Configuration Commands 41
8.4 Member 2 — Configuration 2: Port Security on Access Switch (Free Choice) 46
Configuration Commands 46
8.5 Configuration 1: Inter-VLAN ACL on SW-Core (Plan-Linked) 50
Configuration Commands 50
8.6 Member 3 — Configuration 2: DHCP Snooping on Access Switch (Free Choice) 54
Configuration Commands 54
8.7 Member 4 — Configuration 1: Dynamic ARP Inspection on SW-Core (Plan-Linked) 56
Configuration Commands 56
8.8 Member 4 — Configuration 2: AAA Local Authentication (Free Choice) 59
Configuration Commands 59
9. CONCLUSION 64
10. REFERENCES 65
10.1 Generative AI Prompt Log 66
10.2 List of Abbreviations 67

11. APPENDICES - INDIVIDUAL TECHNOLOGY PROPOSALS 68

11.1 APPENDIX A — MEMBER 1 TECHNOLOGY PROPOSALS 68

11.1.1 VPN Proposal 68

11.1.2 AAA Proposal 68

11.1.3 Secure Network Architecture 69

11.1.4 IDS/IPS Proposal 69

11.2 APPENDIX B — MEMBER 2 TECHNOLOGY PROPOSALS 70

11.2.1 VPN Proposal 70

11.2.2 AAA Proposal 70

Secure Network Architecture Proposal 71

11.2.3 IDS/IPS Proposal 71

11.3 APPENDIX C — MEMBER 3 TECHNOLOGY PROPOSALS 72

11.3.1 VPN Proposal 72

11.3.2 AAA Proposal 72

11.3.3 Secure Network Architecture Proposal 73

11.3.4 IDS/IPS Proposal 73

11.4 APPENDIX D — MEMBER 4 TECHNOLOGY PROPOSALS 74

11.4.1 VPN Proposal 74

11.4.2 AAA Proposal 74

11.4.3 Secure Network Architecture Proposal 75

11.4.4 IDS/IPS Proposal 75

1. INTRODUCTION

1.1 Purpose of the Report

This report provides an extensive network security review and enhancement strategy for Northbridge Savings & Finance, a mid-sized regional financial services company. This report has been initiated by the CTO after being informed of two issues. One, an alert from a regional industry association on the increase in ransomware attacks on mid-size financial organizations. Two, an attack on one of Northbridge's employees through social engineering tactics.

The objectives of this report are to examine and analyze the major security threats Northbridge faces, create a layered security solution that effectively addresses these threats, assess and suggest contemporary security technologies (such as VPN, AAA, secure network design, and IDS/IPS), illustrate the deployment of critical security controls using Cisco Packet Tracer, and provide a cost-effective approach to securing the network at Northbridge prior to third party payment integration going live.

1.2 Scope

Threat modeling of eight specific threats that are applicable to Northbridge's scenario; Layered Security Plan with 26 controls to be implemented against 8 threats; Individual Technology Proposals of each member (4 in total) for Virtual Private Network, AAA solution, network architecture and Intrusion Detection/Prevention System; Group Comparative Analysis and Final Decision on each of the technologies; Network Hardening Techniques Implementation in Cisco Packet Tracer demonstrating 8 different security techniques; Secure Network Architecture Proposal including several firewalls and zones.

This report does not cover financial cost analysis of each of the technologies (considered in selection process), legal/regulatory requirements alignment to financial regulations or full implementation project plan.

1.3 Methodology

The group used a certain methodology to accomplish the task. The first step entailed the analysis of the scenario by studying the Northbridge scenario, critical assets, and vulnerabilities. The second step involved modeling 2 threats independently by each group member using the chain asset-vulnerability-threat-exploit-attack-impact-risk. The third step involved coming up with a plan of action for all 8 threats that have been identified involving 26 controls, which minimize the number of critical controls to the minimum. The fourth step involved researching and suggesting possible solutions for AAA, architecture, IDS/IPS, and VPN independently. The fifth step involved comparing all four solutions for each area and selecting one final solution.

2. ORGANIZATION AND NETWORK SECURITY SCENARIO

2.1 Northbridge Savings & Finance Overview

Northbridge Savings & Finance is an intermediary-sized regional financial service company that provides personal banking services, small business **loans, and digital payments services.** Northbridge has one main office, where the data center is located, along **with six branch** offices in the region employing about **450 employees** in total.

The main office houses the core banking application, customer database, web-based banking, mobile banking, and email services. Branch offices are connected to the main office via dedicated connections. Only a few remote workers and IT support contractors along with two third party contractors need to connect remotely into the internal systems. Northbridge also has recently started integrating with two third party payment processing systems to speed up digital transactions.

Historically, all the security efforts of Northbridge have been directed towards physical security such as vaults, alarm systems, and branch office cameras. Network was designed and expanded over time, without having any network segmentation policy.

2.2 Key Assets

Table 2.1: presents Northbridge's key assets and their importance.

Asset	Importance	Why It Matters
Customer financial and personal data	**Critical**	Prime target; direct financial and regulatory consequences if compromised
Core banking application	**Critical**	Essential for daily operations
Customer database	**Critical**	Holds all customer data
Online banking portal	**Critical**	Public facing; direct customer access
Mobile application	High	Public facing; customer access
Email systems	High	Every employee relies on it
Branch and head-office connectivity	High	Keeps core banking services available
Employee credentials	High	Keys to internal systems
Third-party payment integrations	**Critical** (upcoming)	Extends trust beyond Northbridge
Regulatory compliance and reputation	**Critical**	Underpins customer and regulator confidence

2.3 Current Network Architecture

The network of Northbridge has evolved organically over the period of over ten years without an official segmentation policy. The current architecture is made up of an internet gateway router that is attached to a flat network with head office systems, branch systems, guest Wi-Fi, and point-of-service equipment.

The main features of the current architecture are: a flat network with head office systems, branch systems, guest Wi-Fi, and point-of-service equipment on the same flat network space; no special firewall apart from the basic firewall/router capabilities provided by the internet gateway router; no segmentation (no VLANs, no zones, no internal firewalls); one shared VPN account for all remote users and contractors; no multi-factor authentication at any point; local accounts on every system and application; no intrusion detection/prevention; and no logging/audit capabilities.

3. EXISTING SECURITY WEAKNESSES

3.1 Technical Weaknesses

NO	Weakness	Impact
1	Flattened network with no segmentation	Guest Wi-Fi, branch systems, and core banking environment all accessible to each other
2	Commonly shared VPN account	No personal accountability; no idea which employee accessed systems remotely
3	No MFA anywhere	Credential theft results in full account takeover
4	No firewall	Just a basic router, no packet inspection
5	No IDS/IPS	Uncertainty about reconnaissance and active exploitation until consequences arise
6	No centralized authentication	Each device/application has its own local accounts
7	Local user accounts everywhere	Brittle identity management and password reuse
8	Old branch software	with known vulnerabilities
9	No centralized logging	Even when activities are logged, no one will recognize suspicious behavior
10	Password reuse and sharing	Compromising one password compromises multiple systems
11	Untested backup	Backups present, but restoration was never performed
12	No patch management	Process
13	No data classification	Policy
14	No vendor security evaluation	Third-party integration without assessment
15	Unmanaged BYOD	Personal devices for business use with no policy in place

Table 3.1: lists Northbridge's technical weaknesses.

3.2 Physical Weaknesses

NO	Weakness	Impact
1	Server room with single shared key	No audit trail for server access
2	Lack of camera coverage of the server room	No information who entered and when
3	Lack of security signage	No deterrent to opportunistic attackers
4	Visitors signing in inconsistently at the branches	No record of who visited
5	Lack of badge checking procedure for the visitors	No restriction on the movement of unauthorized people
6	Lack of camera coverage at entrances	No record of who entered
7	Lack of locked network cabinets in at least 2 locations	Controlled access to networking equipment unavailable

Table 3.2: outlines the physical weaknesses in Northbridge.

3.3 Administrative Weaknesses

NO	Weakness	Impact
1	Lack of security governance	No security policies, procedures and accountability
2	Lack of security awareness training	Unpreparedness for social engineering
3	Lack of incident response process	No response to incidents
4	Lack of disaster recovery plan	No disaster recovery procedure
5	Lack of BYOD and remote working policy	Personal devices for business use with no policy
6	Lack of data classification policy	No guidelines on data handling
7	Lack of vendor security evaluation process	Third party is not evaluated prior to integration
8	Password reuse and share common	Weak credentials handling
9	Lack of security awareness programmed	Recently performed vishing campaign stopped because of individual initiative

Table 3.3: outlines the administrative weaknesses in Northbridge

4. THREAT MODELING

4.1 Ransomware via Unsegmented Branch Workstation (Threat 1: Member 1)

Element	Details
Asset	Core banking database and branch-to-head office network connectivity.
Vulnerability	Flat network configuration in Northbridge. Guest Wi-Fi, branch workstations and core banking infrastructure operate from the same network. Some branches operate older versions of applications and operating system software. There is no patch management program in place.
Threat	Ransomware gang is targeting Northbridge because of its position as a mid-size financial institution with sensitive customer data and lack of network segmentation.
Exploit	Exploit involves flat network configuration and the use of older versions of applications and operating systems at branches. Compromising one of the branches would allow lateral movement in the network to the core banking infrastructure.
Attack	Phishing e-mail to branch staff member. Staff member opens attachment, install malware on the branch workstation. Network reconnaissance by malware. Lateral movement from branch workstation to head office workstations. Deploying ransomware across the network, encrypts core banking database. Demanding payment of ransom fee.
Impact	Core banking infrastructure is not accessible. Customer sensitive financial information could be stolen prior to encryption. Reporting to regulators violated. Severe damage to reputation. Potential regulatory fees. Customer loss of trust.
Risk	**CRITICAL** – High likelihood (targeted industry, known vulnerabilities) combined with critical impact (core banking infrastructure unavailable, data breach). The PDF highlights this threat scenario: "several of which began with a single compromised branch workstation and spread rapidly across an unsegmented network."

4.2 Shared VPN Account Abuse (Threat 2: Member 1)

Element	Details
Asset	Remote access infrastructure and internal systems.
Vulnerability	Remote access is provided through a single shared VPN account used interchangeably by all support contractors and remote staff. There are no MFA and no individual accountability. In the PDF, it is stated that "the bank has no reliable way of knowing who actually accessed its systems remotely at any given time."
Threat	An adversary uses shared VPN credentials to access Northbridge's internal systems without authorization.
Exploit	The adversary exploits the shared VPN and absence of MFA. As a result, it is impossible to identify the actual person logging into the account. The attacker can take advantage of the credentials being shared, written down, or stolen via phishing attacks to log into a legitimate account.
Attack	The attacker acquires the shared credentials of the account. Then, the attacker accesses Northbridge's VPN. As there is no MFA implemented, the password-only authentication works. The attacker explores the network and either exfiltrates data or installs malware. No individual is accountable since the logs show only the shared account
Impact	Unauthorized access to the internal network. No identification means no traceability of the breach. Regulatory problems related to lack of access control. Loss of customer trust.
Risk	**HIGH** - It is insecure to share credentials; this issue is confirmed in the PDF as the existing practice. High impact due to network access of the adversary. Lack of MFA and accountability prevent Northbridge from detecting and attributing the breach. Two contractors and remote workers share one account.

4.3 Phishing/Credential Theft via Social Engineering (Threat 3: Member 2)

Element	Details
Asset	Credentials of the employees and email system.
Vulnerability	The company lacks security awareness training programmed. Many people reuse passwords and share them between branches of offices. The document presents the case of vishing where a person pretending to be from "IT Helpdesk" asks an employee for his/her password. The employee doubts but does not give it away "only by that individual's own instinct, not by any policy, training, or process."
Threat	An attacker impersonating IT support or another authority persuades the employee to reveal his/her credentials.
Exploit	The attacker takes advantage of lack of security awareness training and reuse of passwords. The employee believes in a pretext like the call or phishing email from IT helpdesk and gives the password away.
Attack	Research of employees by the attacker; call/email to an employee; claim to belong to IT Helpdesk; create sense of urgency; get a password from an employee; use credentials to access email and internal systems; because passwords are reused, one set of credentials might work on many systems.
Impact	Compromises of the credentials results in other attacks like ransomware and data theft; reputation damage and regulatory implications in case customer data is compromised.
Risk	**HIGH** - A vishing attack took place in Northbridge; a high impact is possible because credentials grant access to email and internal systems; passwords are reused; the document describes the specific vishing attack and the lack of training .

4.4 Third-Party Payment Integration Compromise (Threat 4: Member 2)

Element	Details
Asset	Integrations for third party payment processing.
Vulnerability	Northbridge lacks vendor security assessment process. Lack of segmentation between third-party systems and Northbridge internal network. Integration is expected to become operational within two quarters.
Threat	Attack on third-party system through which a connection with Northbridge's system is established.
Exploit	Exploits the trust relationship between Northbridge and the third-party provider. Due to lack of segregation or vendor assessment, the compromised third-party systems have access to Northbridge's network
Attack	Third-party's systems are breached by the attacker. The attacker then uses the connection provided by the third-party to get access to Northbridge's system. No segregation allows for lateral movement inside the Northbridge network. Attackers gain access to payment information, customers' information or install malware. This attack will likely go undetected as the traffic is coming from a trusted source.
Impact	Financial fraud. Breach of regulatory compliance. Severe reputational damage. Loss of customer trust. Liability issues.
Risk	**CRITICAL** - The impact is critical since payment integration has an effect on finances and customer data. The likelihood is medium due to prevalence of supply-chain attacks and lack of vendor assessment process. The PDF clearly states that this is a "critical dependency" and vendor assessment process does not exist.

4.5 Unauthorized Database Access via Insider Misuse (Threat 5: Member 3)

Element	Details
Asset	Customer database.
Vulnerability	Every system and application has a unique set of local user accounts. There is no centralized logging or audit trail. There is no data classification policy, so the staff does not know which data requires additional protection. Password reuse and password sharing are common practices.
Threat	The insider uses local user accounts and no centralized logging. In such an environment, insiders can steal data and cover their tracks since there is no audit trail.
Exploit	The insider uses local user accounts and no centralized logging. In such an environment, insiders can steal data and cover their tracks since there is no audit trail.
Attack	Insider logs into the database with their legitimate local user account. Insider executes queries and exports customer data. Due to the absence of centralized logging, this attack goes unnoticed. Insider destroys local logs or uses shared local user accounts to delete tracks. Data is stolen and used for fraud. Without centralized logging, Northbridge cannot know the extent of the data breach and who carried out the attack.
Impact	Data breach with fines. Damage to reputation. Loss of customer confidence.
Risk	**HIGH** - Likelihood of an attack is medium because insiders need motivation to commit such an attack, but Northbridge does not have centralized logging and data classification. Thus, insiders find it easier to carry out attacks. Impact is high because customer data is the most valuable asset. In the provided PDF, it is said that there is "no centralized logging or audit trail across systems" and "password reuse as well as password sharing is common among branch office staff."

4.6 Data Loss/System Failure Due to Untested Backups (Threat 6: Member 3)

Element	Details
Asset	Core banking database and its backups
Vulnerability	Backups of the core banking database are present but never tested for successful restore. There are no documented disaster recovery or incident response plans.
Threat	A ransomware attack/hardware failure destroys live data and causes the backup restore to fail.
Exploit	The attacker/failure exploits untested backups. After attempting the restore, backups are discovered to be corrupt, incomplete or otherwise non-functional.
Attack	Ransomware attacks the live core banking database. Northbridge attempts restore from the backup. The restore attempt fails. Northbridge employees have no DR plan to refer to and consequently don't know how to respond. The data is irretrievably lost and Northbridge cannot continue operation.
Impact	Complete lack of business continuity. Northbridge cannot provide any services to its customers. Regulatory violation. Potential closure.
Risk	**CRITICAL** - The likelihood is medium due to the necessity of a triggering event but is supported by the PDF where it is clearly stated that "backups of the core banking database exist but have never been tested for successful restoration, and no documented disaster recovery or incident response plan exists."

4.7 Online Banking Portal Attack (SQLi/XSS) (Threat 7: Member 4)

Element	Details
Asset	Online banking portal.
Vulnerability	Northbridge does not have a firewall. There are no IDS or IPS. There is no WAF. The portal is open to the internet. Only basic firewall and router functions are in place.
Threat	A hacker takes advantage of a web application weakness. This weakness could be something like SQL injection or XSS. The hacker gains access to the portal or its database.
Exploit	The hacker uses input validation or bad output encoding in the online banking portal. SQL injection gives the hacker access to the database. XSS lets the hacker steal sessions. Get login details.
Attack	The hacker looks for problems in the online banking portal. The hacker finds a problem with SQL injection or XSS. The hacker uses the problem to get into the database or steal a customer's session. The hacker takes customer data. Makes unauthorized transactions. Without IDS or IPS or WAF the attack is not noticed.
Impact	Customer data is stolen. Financial fraud happens. There are fines from rules and regulations. The company's reputation is harmed. Customers lose trust in the service.
Risk	**HIGH** - The chance of this happening is high because web applications that are open to the internet are always being attacked. The damage is high because customer money information is in danger. The PDF says specifically: "no dedicated firewall, no intrusion detection or prevention capability" and the online banking portal is "exposed to the internet."

4.8 Unmanaged BYOD Endpoint Compromise (Threat 8: Member 4)

Element	Details
Asset	Employee credentials and the internal network.
Vulnerability	Northbridge lets staff work from home. Use their own computers and phones but no rules or advice are in place. Northbridge has no software that protects devices. There is no BYOD policy.
Threat	If an employees personal phone or computer gets malware the virus can jump onto Northbridges network and spread.
Exploit	The attacker takes advantage of a device that Northbridge does not control. Because there is no protection or policy the infected device can connect to the network without being checked.
Attack	The malware lands on the employees device through a download or a dangerous app. The employee plugs the device into Northbridges network. The malware then moves to internal computers. It can grab login details or plant hidden back doors. With no protection Northbridge never sees the infection.
Impact	The malware can keep spreading. Login details can be stolen. A ransomware attack could start. There could be problems.
Risk	**MEDIUM-HIGH**. The chance for this to happen is medium because many people use devices and they often have malware. The document confirms there is no policy. The damage could be medium-high because the virus can spread and steal credentials. The document says: "Northbridge also allows work from home and has allowed staff to use their personal machines and phones for work, but no guidance or rules are, in place.”

5. COMBINED LAYERED SECURITY PLAN

5.1 Master Control List

Control ID	Control Name	Type	Description
C01	**Network Segmentation & Zone Isolation Technical**	Technical	Segregation of the network into logical zones (Users, Servers, Database, Management, Branches, DMZ, Third Parties, Remote Access) using VLANs and firewalls. Includes segregation of third-party partners.
C02	**Next-Generation Firewall (NGFW)**	Technical	Use of multiple firewalls in the perimeter, internal and database zone. Includes stateful inspection, application awareness, and IPS capability.
C03	**Multi-Factor Authentication & Secure Remote Access**	Technical	Restricting remote access and privileged user access and email to require second authentication factor (TOTP, push, hardware token). Replace current shared account for VPN access with per user account.
C04	**Third-Party Risk Management**	Administrative	Policy for assessing security posture of third-party payment providers during evaluation and after integration. Include connection and access policy.
C05	**IDS/IPS**	Technical	implementation of network-based IDS/IPS solution in perimeter, internal and database zone. Includes signature and anomaly-based IDS/IPS capabilities.
C06	**Endpoint Security Management**	Technical	Combination of endpoint protection (EDR/antivirus), network access control (NAC) and patch management solutions on all endpoints.

C07	**Security Awareness Training**	Administrative	Training of all personnel on phishing, social engineering, passwords and reporting
C08	**Centralized AAA**	Technical	implement RADIUS/TACACS+ or IAM technology for centralized authentication, authorization, and accounting on all devices and applications.
C09	**Centralized Logging and SIEM**	Technical	Maintain logs on all systems using one centralized platform.
C10	**Data Classification and Access Control**	Administrative + Technical	Determine categories of data and handling requirements. Enforce least privilege principle and detect inside threats.
C11	**Backup Testing, Disaster Recovery & Business Continuity Planning**	Admin + Tech	Conduct regular backup testing. Document and practice DR and BCP plan.
C12	**Incident Response Plan**	Administrative	documented procedure to identify, react and recover from security incidents.
C13	**Web Application Security**	Technical + Administrative	Secure the online banking portal from SQLi, XSS and other web application attacks.
C14	**BYOD and Remote Work Policy**	Administrative	Develop policy for BYOD and remote working. Specify security requirements and network access policy.
C15	**Password Policy**	Administrative	Establish password policies: strong passwords, do not reuse or share, and rotate regularly.
C16	**Physical Access Controls**	Physical	Implement badge or biometric access instead of common key for server room. Install cameras and signs. Secure network cabinets.

5.2 Control-to-Threat Mapping

Control	Threats/Attacks Addressed
C01 (Network Segmentation & Zone Isolation Technical)	**T1, T4, T5, T7, T8** - stops ransomware lateral spread, segregates guest Wi-Fi from core banking environment, keeps third-party traffic to DMZ, constrains scope of compromised branch endpoint, prevents database access
C02 (Next-Generation Firewall) (NGFW)	**T1, T4, T5, T7, T8** - enforce zone boundaries, block malicious traffic, inspect inter-zone traffic, protect public facing services, prevent lateral movement in zones
C03 (Multi-Factor Authentication & Secure Remote Access)	**T1, T2, T3, T5, T8** - prevent credential-based attacks, protect shared VPN accounts, stop phishing credential theft, prevent insider abuse, secure BYOD access
C04 (Third-Party Risk Management)	**T4 -** third party payment partners comply with security standards before integration, outline connection methods and access of third-party partner, minimize supply chain risk
C05 (IDS/IPS)	**T1, T2, T4, T5, T7, T8 -** detect and block ransomware, web-based attacks, insider misuse and malicious traffic in all zones
C06 (Endpoint Security Management)	**T1, T3, T7, T8 -** stops malware execution in workstations, prevent phishing payload execution, enforce device compliance, patch vulnerabilities in branch endpoints and BYOD
C07 (Security Awareness Training)	**T1, T3, T8 -** reduce phishing success rate, increase social engineering awareness, secure BYOD use
C08 (Centralized AAA)	**T1, T2, T3, T5, T7, T8 -** single point of authentication, no local accounts, accountability for all systems
C09 (Centralized Logging and SIEM)	**T1, T2, T3, T4, T5, T6, T7, T8 -** visibility for all systems, threat detection for all systems, incident response, audits
C10 (Data Classification and Access Control)	**T4, T5 -** sensitive data handling, restricted access for insiders, monitoring of suspicious activity

C11 (Backup Testing, Disaster Recovery & Business Continuity Planning)	**T1, T6 -** recovery from ransomware, no permanent data loss thanks to backups, business continuity
C12 (Incident Response Plan)	**T1, T2, T3, T4, T5, T6, T7, T8 -** consistent response to all threats, minimize impact, recovery
C13 (Web Application Security)	**T1, T4, T7 -** secure online banking portal from SQL injection, cross-site scripting and other web-based attacks, secure coding, find vulnerabilities before attackers exploit them
C14 (BYOD and Remote Work Policy)	**T2, T8 -** personal device usage policy and remote work policy for lower endpoint risk
C15 (Password Policy)	**T2, T3, T5 -** password security policy, prevent password reuse and sharing, reduce risk of credentials being compromised
C16 (Physical Access Controls)	**T1, T5 -** no physical access to server room and network equipment

5.3 Function × Category Dual-Axis Table

Function	Administrative	Technical	Physical
Preventive	C04, C07, C10, C14, C15	C01, C02, C03, C05, C06, C08, C13	C16
Detective	C10, C13	C05, C06, C09	C16
Deterrent	C07, C12, C10	C02, C05	C16
Corrective	C10, C12, C15	C02, C05, C06, C08	-
Recovery	C11	C11	-
Compensating	C14, C10	C06	-

Explanation of cell classifications:

- C01 (Network Segmentation) is Preventive (Technical). It prevents lateral movement by design.
- C02 (NGFW) appears in Preventive, Deterrent and Corrective (Technical). It prevents traffic deters attackers through visibility and can correct (block) active attacks.
- C05 (IDS/IPS) appears in Preventive, Detective, Deterrent and Corrective (Technical). It prevents (IPS blocks) detects (IDS alerts) deters (attackers know they may be detected) and corrects (blocks attacks).
- C06 (Endpoint Security Management) appears in Preventive, Detective, Corrective and Compensating (Technical). It prevents malware, detects infections, corrects them through remediation and patching and compensates for BYOD devices through NAC.
- C07 (Security Awareness Training) is Preventive and Deterrent (Administrative). It prevents phishing and deters insiders who know they are monitored.
- C09 (Centralized Logging & SIEM) is Detective (Technical). Its primary role is detection, correlation and audit.

- C10 (Data Classification & Access Control) appears in Preventive, Detective, Deterrent, Corrective and Compensating (Administrative). It prevents access detects unusual behavior deters malicious insiders, corrects over-provisioning and compensates when other controls fail.
- C11 (Backup Testing, DR & BCP) appears in Recovery (Administrative and Technical). It combines recovery (DR and BCP) with technical recovery (backup restoration).
- C12 (Incident Response Plan) is Deterrent and Corrective (Administrative). It deters attackers (they know a response is planned). Corrects incidents.
- C13 (Web Application Security) appears in Preventive and Detective (Administrative and Technical). The WAF is Preventive and Detective (Technical) while secure coding and vulnerability scanning are Preventive and Detective (Administrative).
- C14 (BYOD & Remote Work Policy) is Preventive and Compensating (Administrative). It prevents device access and compensates for the lack of full endpoint control on personal devices.
- C16 (Physical Access Controls) appears in Preventive, Detective and Deterrent (Physical). It prevents entry detects entry, through logs and cameras and deters opportunistic intruders through visible signage and badge-checking.

5.4 Control Minimization Justification

Northbridge starts from a weak base: no MFA, no special firewall, no IDS/IPS no way to manage access in one place, no way to track activity in one place no way to label data no training for people on security no plan for recovery after an incident and no plan for what to do during an incident and the network is completely open with no divisions. Since many basic protections are not there the group could have suggested fifty or more small specific controls. One for each risks each weakness and each part of the system. Instead, they made 16 big general controls, each one that handles several risks and fits into many parts of the Function × Category table.

Controls that were chosen because they handle risks.

C01 (Network Segmentation & Zone Isolation) was picked as one control that reduces five risks (T1, T5, T6, T7, T8). A smaller choice would have been to make controls for dividing the branch network, splitting the database, separating guest Wi-Fi keeping third parties away and managing personal devices. That would have added four controls to the plan. Since the way to do this. Using VLANs and rules between areas. Is the same for all of them, one control for segmentation covers all five situations. The smaller way would have made the list of controls longer with the same things and made it harder to put into place and check.

C03 (MFA & Secure Remote Access) handles five risks (T1, T2, T3, T5, T8). A smaller choice would have been to make controls for MFA on the VPN, MFA on email MFA on special accounts and MFA on personal devices. That would have added three controls without making things safer because MFA is one thing no matter where it is used. Combining the need for a VPN with MFA also makes sense: both are there to make sure only the right people get into the system remotely so putting them together as one control avoids repeating the same thing.

C05 (IDS/IPS) covers six threats, T1, T2, T4, T5, T7 and T8. The narrower alternative would have required IDS for the perimeter separate IPS for the internal network and separate monitoring for the database zone adding two extra controls. One IDS/IPS deployment with sensors placed in zones achieves the same coverage.

C08 (Centralized AAA) covers six threats. The narrower alternative would have required authentication systems for network devices, applications and remote access adding two extra controls and creating the same fragmentation that caused Northbridges current problem of local accounts on every device.

C09 (Centralized Logging & SIEM) covers all eight threats. This control is the reused element in the plan. Without it each threat would need a detection mechanism. With it one platform ingests logs from firewalls IDS/IPS, endpoints, AAA and applications. Correlates them to detect every one of the eight threats.

C12 (Incident Response Plan) also covers all eight threats. A narrower alternative would have been response procedures for ransomware, phishing, insider misuse, third-party compromise and so on. One overarching IR plan with threat-specific playbooks achieves the result using a single control.

What was. Rejected in favor of broader controls.

The group considered narrower controls before consolidating them. We found that separate branch, database and guest Wi-Fi segmentation controls were rejected in favor of C01 because the same segmentation mechanism applies in each case. We rejected VPN, email and privileged-account MFA controls in favor of C03 because MFA is one capability. We rejected perimeter IDS, internal IPS and database monitoring controls in favor of C05 because a single IDS/IPS platform with multiple sensors is simpler and cheaper. We rejected RADIUS for network devices LDAP for applications and SSO for web in favor of C08 because one centralized AAA platform can serve all three. We rejected ransomware, phishing and insider IR playbooks in favor of C12 because one IR plan with threat-specific annexes is more maintainable. We rejected backup encryption, backup testing and offsite backup controls in favor of C11 because these are all components of a single backup and DR capability.

We merged vendor assessment and third-party access policy controls into C04 because both govern the same relationship with external partners. We merged endpoint protection, NAC and patch management controls into C06 because all three address endpoint security management. We merged data classification, least privilege and insider-threat-monitoring controls into C10 because all three govern who may access what. We merged WAF, secure coding and vulnerability scanning controls into C13 because all three protect web applications, across their lifecycle.

Deliberate redundancy that was kept.

The group deliberately kept redundancy in two areas. C02 (Next-Generation Firewall) and C05 (IDS/IPS) overlap on five threats: T1, T4, T5, T7 and T8. A critic might wonder why both controls are kept. The reason is that they do things. C02 stops traffic based on rules. It is control. C05 looks for patterns that slip past the firewall. These can include zero-day attacks, encrypted traffic or insider actions that appear normal. The IPS part of C05 can. Prevent and correct threats. If C05 were removed and only C02 was used Northbridge would not see attacks that the firewall rules do not block. This is what the PDF says: "no intrusion detection or prevention capability anywhere on the network leaving the bank blind to reconnaissance or active compromise until damage is already visible." If C02 were removed and only C05 was used Northbridge would have no line of defense. That is because every packet would go through the IDS/IPS, which is not built to filter at line rate. The redundancy is therefore intentional and needed. One control prevents, the detects.

A second deliberate redundancy is between C06 (Endpoint Security Management) and C01 (Network Segmentation). Both deal with BYOD and branch endpoints (T1, T8). C06 protects the device itself. C01 limits what the device can reach if it gets compromised. If C06 fails and malware gets past the endpoint agent C01 still stops the device from reaching the database zone. If C01 is

bypassed C06 can still. Fix the malware. The redundancy is again intentional because BYOD and branch endpoints are areas that're hard to control and are often used by attackers.

Why fewer broad controls more efficient.

Cutting the plan from over fifty controls down to sixteen gives Northbridge benefits. First implementation is easier for an IT team. Sixteen controls can be rolled out in steps. Fifty would be too much for the team to handle. Second auditing is simpler. A shorter list of controls is easier to match with rules and to prove during an audit. Third maintenance is lower. Fewer controls mean updates, fewer vendor agreements and less configuration drift. Fourth training is easier. Staff only need to learn several controls. This leads to compliance. Fifth cost is lower. Fewer controls mean costs for licensing, hardware and training. This is very important for Northbridge. The IT budget has always been used mostly for security, not IT infrastructure.

How the controls work together as defense, in-depth.

The sixteen controls are not separate. They work together in nine layers of defense. Layer 1 (Governance & Policy) includes C04, C07, C10, C12, C14 and C15. Layer 2 (Perimeter Security) includes C02, C05 and C13. Layer 3 (Network Segmentation) includes C01, C02 and C06. Layer 4 (Identity & Access) includes C03, C08, C10 and C15. Layer 5 (Endpoint Protection) includes C06. Layer 6 (Data Protection) includes C10 and C11. Layer 7 (Visibility & Detection) includes C05, C09 and C13. Layer 8 (Response & Recovery) includes C11 and C12. Layer 9 (Physical Security) includes C16. Each of the eight threats is covered by at least four layers. So, no single control failure leads to an attack. If an attacker gets past the firewall (C02) the IDS/IPS (C05) will see them. If they get past the IDS/IPS, segmentation (C01) limits their movement. If they break into a segment MFA (C03) and least privilege (C10) limit what they can do. If they steal data, centralized logging (C09) records it and the IR plan (C12) react.

6. GROUP TECHNOLOGY EVALUATION

6.1 VPN — Comparative Evaluation & Final Selection

OpenVPN is the proposal from **Member 1. WireGuard is the proposal from Member 2. Cisco AnyConnect is the proposal from Member 3. IPsec Site-to-Site is the proposal from Member 4**. Table 6.1 shows a comparison of OpenVPN, WireGuard, Cisco AnyConnect and IPsec Site-, to-Site using the criteria.

Criteria	OpenVPN	WireGuard	Cisco AnyConnect	IPsec Site-to-Site
Security	Strong (AES-256)	Strong (ChaCha20)	Very strong (AES-256)	Strong (AES-256)
Authentication	Certs, LDAP, MFA via plugin	Certs/keys only	Certs, SAML, native MFA	Certs, PSK
MFA Support	Plugin-based	Limited	Native, excellent	Limited
Scalability	Good	Excellent	Excellent	Good
Performance	Moderate	Excellent	Good	Good
Remote Worker Support	Excellent	Good	Excellent	Moderate
Branch Connectivity	Good	Good	Excellent	Excellent
Management	Moderate	Moderate	Excellent (centralized)	Complex
Logging	Good	Basic	Excellent	Good
Cost	Free	Free	Licensed	Free
Integration	Flexible	Flexible	Cisco ecosystem	Router-based
Northbridge Fit	Good	Good	Excellent	Excellent for branches only

Table 6.1: VPN Comparison

I think Cisco AnyConnect is the option for Northbridge because Cisco AnyConnect gives native MFA tracks individual users offer central management and works for both remote workers and branch offices. OpenVPN is free and flexible. It needs extra plugins for MFA and more manual management. WireGuard is fast and secure. It offers only limited MFA and logging. IPsec works well for branch connections. It is not as good for remote workers and offers limited MFA. Therefore, **Cisco AnyConnect is the fit, for Northbridge's security and management needs.**

6.2 AAA — Comparative Evaluation & Final Selection

The four proposals are **Cisco ISE (Member 1) FreeRADIUS. Ldap (Member 2) Windows NPS (Member 3) and Keycloak (Member 4).** Table 6.2 compares them.

Criteria	Cisco ISE	FreeRADIUS + LDAP	Windows NPS	Keycloak
Centralized Authentication	Excellent	Good	Excellent	Excellent
Authorization	Excellent (policy-based)	Good	Good	Good
Accounting/Logging	Excellent	Good	Good	Good
Integration	Cisco ecosystem	Flexible	Microsoft ecosystem	Flexible
Scalability	Excellent	Good	Good	Good
Security	Very strong	Strong	Strong	Strong
MFA Support	Excellent (native)	Plugin-based	Azure MFA	Excellent (native)
Network Device Support	Excellent	Excellent	Good	Limited
Application SSO	Good	Limited	Limited	Excellent
BYOD/NAC Support	Excellent	Limited	Limited	Limited
Cost	Very expensive	Free	Licensed (Windows)	Free
Northbridge Fit	Good but expensive	Excellent	Good	Good

Table 6.2:AAA Comparison

FreeRADIUS + LDAP is the option for Northbridge because it provides centralized authentication supports different network devices and is free and open source. Cisco ISE offers NAC and MFA, but it costs too much. Windows NPS gives AD integration, but it is more suited to Microsoft environments and needs licensing. Keycloak offers good application SSO and MFA. It has limited support for network devices. Therefore **FreeRADIUS + LDAP best meets Northbridge's security, compatibility and budget requirements**.

6.3 Network Architecture — Comparative Evaluation & Final Selection

The four proposals are **Zone-Based Firewall (Member 1) DMZ plus Dual-Firewall (Member 2) Micro-Segmentation (Member 3) and Zero-Trust (Member 4)**. Table 6.3 compares them.

Criteria	Zone-Based Firewall	DMZ + Dual-Firewall	Micro-Segmentation	Zero-Trust
Segmentation	Excellent	Good	Excellent	Excellent
Multiple Firewalls	Yes (multiple)	Yes (two)	Yes (virtual)	Yes (policy-based)
DMZ Support	Yes	Yes	Yes	Yes
Complexity	Moderate	Moderate	High	High
Cost	Moderate	Moderate	High	High
Scalability	Good	Good	Excellent	Excellent
Protects Public Services	Yes	Yes	Yes	Yes
Protects Internal Resources	Yes	Partial	Yes	Yes
Insider Threat Protection	Good	Limited	Excellent	Excellent
Lateral Movement Prevention	Good	Limited	Excellent	Excellent
Practical for Northbridge	Excellent	Excellent	Good but complex	Good but ambitious
Northbridge Fit	Excellent	Excellent	Good	Good but ambitious

Table 6.3: Architecture Comparison

I think Zone-Based Firewall Architecture is the option for Northbridge. Zone-Based Firewall Architecture gives network segmentation, multiple firewalls, protection for public and internal resources and scalability. DMZ + Dual-Firewall is. Simple but gives fewer zones. Micro-Segmentation offers control but is too complex and costly for Northbridge's small IT team. Zero-Trust gives security but requires major investment and organizational changes. Therefore **Zone-Based Firewall Architecture gives a balance of security, practicality and cost.**

6.4 IDS/IPS — Comparative Evaluation & Final Selection

The four proposals are **Snort (Member 1) Suricata (Member 2) Cisco Firepower (Member 3) and Zeek (Member 4).** Table 6.4 provides a comparison of these four proposals.

Criteria	Snort	Suricata	Cisco Firepower	Zeek
Signature Detection	Excellent	Excellent	Excellent	Limited
Anomaly Detection	Limited	Yes	Yes	Yes
Prevention	Yes (inline)	Yes (inline)	Yes	No (monitor only)
Network Visibility	Good	Excellent	Excellent	Excellent
Logging	Good	Excellent	Excellent	Excellent
Alerting	Good	Excellent	Excellent	Good
Integration	Flexible	Flexible	Cisco ecosystem	Flexible
Performance	Good	Excellent (multi-threaded)	Excellent	Good
Scalability	Good	Excellent	Excellent	Good
Management	Moderate	Moderate	Excellent (centralized)	Moderate
Cost	Free	Free	Expensive	Free
Northbridge Fit	Good	Excellent	Good but expensive	Good (but no IPS)

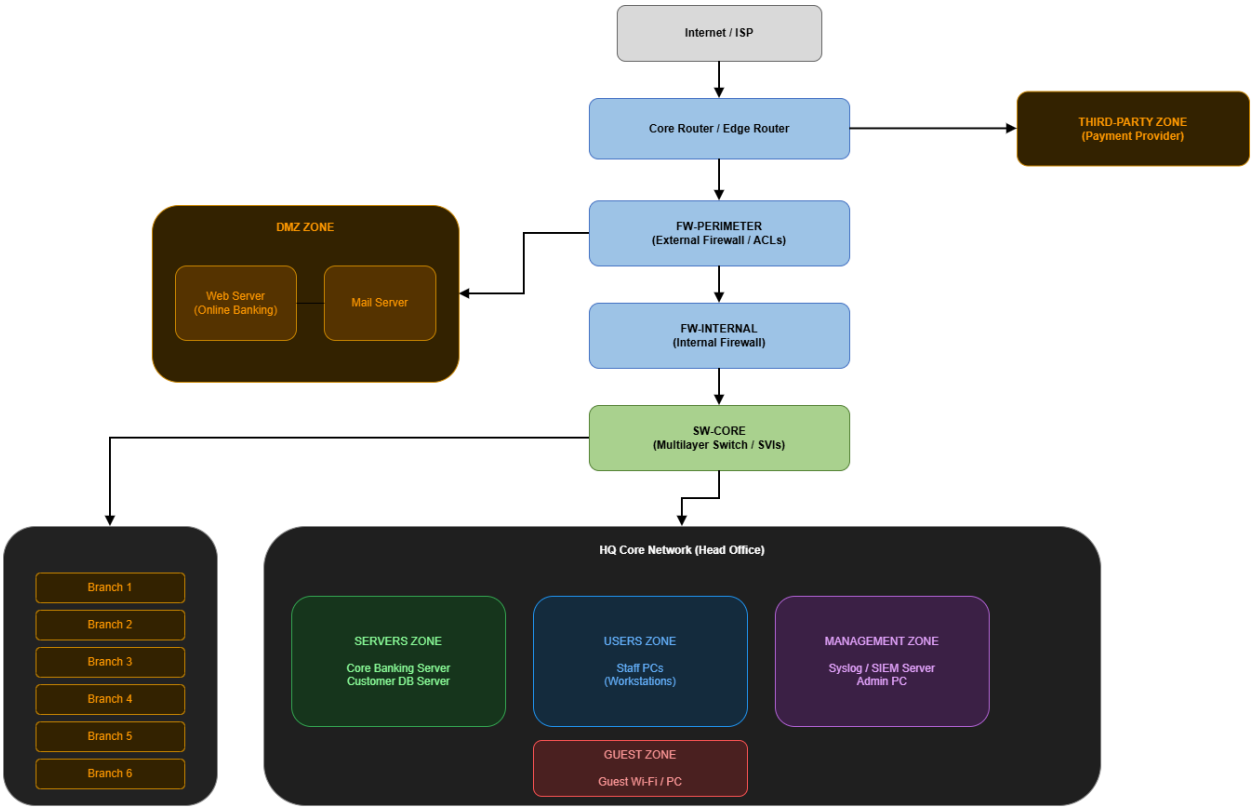
Table 6.4: IDS/IPS Comparison

Suricata is the choice for Northbridge because it offers signature-based detection and anomaly-based detection. It also supports inline prevention delivers performance and provides detailed logging. Best of all it does not require any licensing cost. Snort offers signature-based detection but has limited ability to detect anomalies. Cisco Firepower includes features for enterprise environments, but it is too expensive for Northbridge's budget. Zeek gives network visibility and comprehensive logging, but it cannot block attacks. **So Suricata provides a balance of security, performance and cost.**

7. NETWORK SECURITY ARCHITECTURE

7.1 Architecture Overview

The proposed network security architecture for Northbridge Savings & Finance is a layered defence-in-depth design that enforces zone-based separation. I see the network security architecture for Northbridge Savings & Finance centred on the Head Office (HQ) and linking all six branch offices and external partners with a set of boundaries. At the top of the hierarchy the Internet/ISP links to the Core Router (Edge Router). The Core Router for Northbridge Savings & Finance is the gate and directs traffic either to the external Third-Party Zone or deeper into the primary security stack. Below the Core Router sits the Perimeter Firewall (FW-PERIMETER) which enforces external access control lists (ACLs). The FW-PERIMETER isolates the DMZ Zone, which holds services such as the Web Server and Mail Server keeping them from reaching the internal network directly. Traffic that is meant for the internal network must go through a defence layer the Internal Firewall (FW-INTERNAL). This firewall links to the Core Switch (SW-CORE) a switch that uses Switched Virtual Interfaces (SVIs) to move traffic between the internal VLANs. The SW-CORE connects to the HQ Core Network, which holds the servers, user workstations, management systems and the guest network. All six Branch Offices also plug into the SW-CORE, so their traffic is verified and filtered before it reaches the Head Office systems.



8. Network Hardening Configurations

8.1 Member 1 — Configuration 1: VLAN Segmentation on SW-Core (Plan-Linked)

- **Objective**: Segregate Head Office's network into VLANs for users, servers, management, and guests, and implement ACL to limit traffic from User Zone to specific services on the Application server only.
- **Control**: C01 – Network Segmentation
- **Threat(s):** T1 (Lateral Movement of Ransomware), T5 (Unauthorized Access to Database), T8 (Compromise of BYOD Endpoint)
- **Device**: Cisco 3560 Multilayer Switch (SW-Core)

Configuration Commands

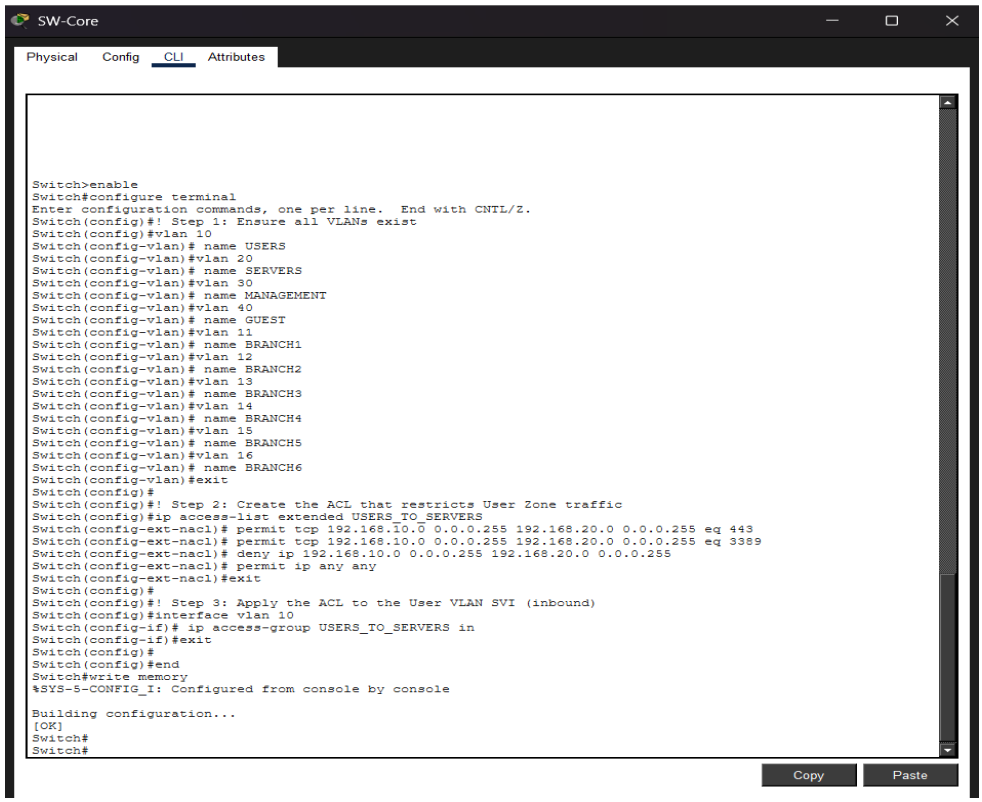


Figure 1:Configuration commands on SW-Core

Description: Illustrates the complete VLAN & ACL configuration that is performed on SW-Core. Provides proof for using the commands for VLAN segmentation.

```
Building configuration...
[OK]
Switch#
Switch#show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/5, Fa0/6, Fa0/7, Fa0/8
                                                Fa0/9, Fa0/10, Fa0/11, Fa0/12
                                                Fa0/13, Fa0/14, Fa0/15, Fa0/16
                                                Fa0/17, Fa0/18, Fa0/19, Fa0/20
                                                Fa0/21, Fa0/22, Fa0/23, Fa0/24
                                                Gig0/1, Gig0/2
10   USERS                            active
11   BRANCH1                          active
12   BRANCH2                          active
13   BRANCH3                          active
14   BRANCH4                          active
15   BRANCH5                          active
16   BRANCH6                          active
20   SERVERS                          active
30   MANAGEMENT                       active
40   GUEST                            active    Fa0/4
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
Switch#
Switch#
```

Figure 2: show vlan brief

Description: Illustrates all the VLANs (VLAN 10, 11 to 16, 20, 30, 40) as being ACTIVE along with their corresponding ports. Indicates that VLAN segmentation is configured properly.

```
Switch#
Switch#show access-lists
Extended IP access list USERS_TO_SERVERS
    10 permit tcp 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255 eq 443
    20 permit tcp 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255 eq 3389
    30 deny ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
    40 permit ip any any
```

Figure 3: show access-lists command output

Description: Illustrates the USERS_TO_SERVERS ACL with 5 rules (permitting ICMP to App Server, permitting 443, permitting 3389, denying all access to the server subnets and permitting all).

```
Switch#show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
FastEthernet0/1        10.0.0.6        YES manual up                    up
FastEthernet0/2        unassigned      YES unset  up                    up
FastEthernet0/3        unassigned      YES unset  up                    up
FastEthernet0/4        unassigned      YES unset  down                  down
FastEthernet0/5        unassigned      YES unset  down                  down
FastEthernet0/6        unassigned      YES unset  down                  down
FastEthernet0/7        unassigned      YES unset  down                  down
FastEthernet0/8        unassigned      YES unset  down                  down
FastEthernet0/9        unassigned      YES unset  down                  down
FastEthernet0/10       unassigned      YES unset  down                  down
FastEthernet0/11       unassigned      YES unset  down                  down
FastEthernet0/12       unassigned      YES unset  down                  down
FastEthernet0/13       unassigned      YES unset  down                  down
FastEthernet0/14       unassigned      YES unset  down                  down
FastEthernet0/15       unassigned      YES unset  down                  down
FastEthernet0/16       unassigned      YES unset  down                  down
FastEthernet0/17       unassigned      YES unset  down                  down
FastEthernet0/18       unassigned      YES unset  down                  down
FastEthernet0/19       unassigned      YES unset  down                  down
FastEthernet0/20       unassigned      YES unset  down                  down
FastEthernet0/21       unassigned      YES unset  down                  down
FastEthernet0/22       unassigned      YES unset  down                  down
FastEthernet0/23       unassigned      YES unset  down                  down
FastEthernet0/24       unassigned      YES unset  down                  down
GigabitEthernet0/1     unassigned      YES unset  down                  down
GigabitEthernet0/2     unassigned      YES unset  down                  down
Vlan1                  unassigned      YES unset  administratively down down
```

Copy Paste

Figure 4: show ip interface brief command output

Description: Illustrates all the VLAN SVIs as being up/up with their assigned IP addresses. Indicates that the inter-VLAN routing.

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Request timed out.
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 3, Lost = 1 (25% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\>
```

Figure 5: Test 1: HQ-PC1 → App Server

Description: Ping successful from HQ-PC1 to App Server (192.168.20.10), four replies received. Demonstrates that the ACL allows traffic from users to app servers.

```
C:\>ping 192.168.20.11

Pinging 192.168.20.11 with 32 bytes of data:

Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.

Ping statistics for 192.168.20.11:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>
```

Figure 6: Test 2: HQ-PC1 to DB Server (access denied)

Description: Ping to DB Server (192.168.20.11) results in "Destination host unreachable" message from 192.168.10.1. This confirms the ACL

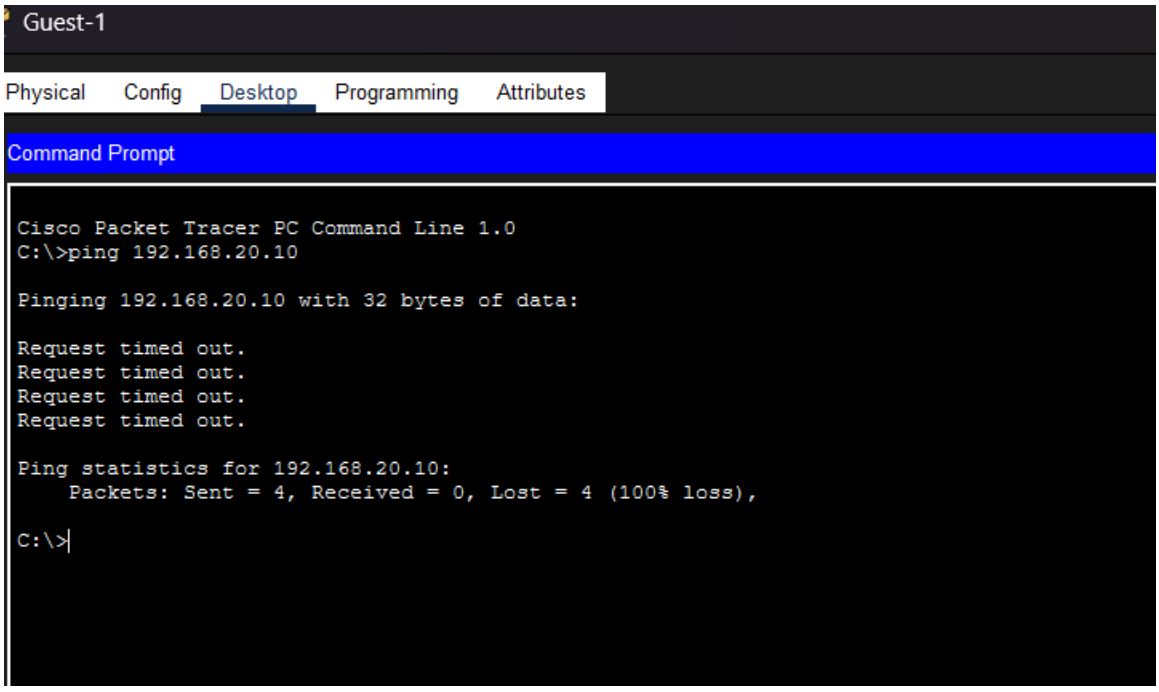


Figure 7: Test 3: Guest PC → App Server (denied)

Description: Ping from Guest PC to App Server times out. Demonstrates Guest Zone is separated from other zones and internal servers**.**

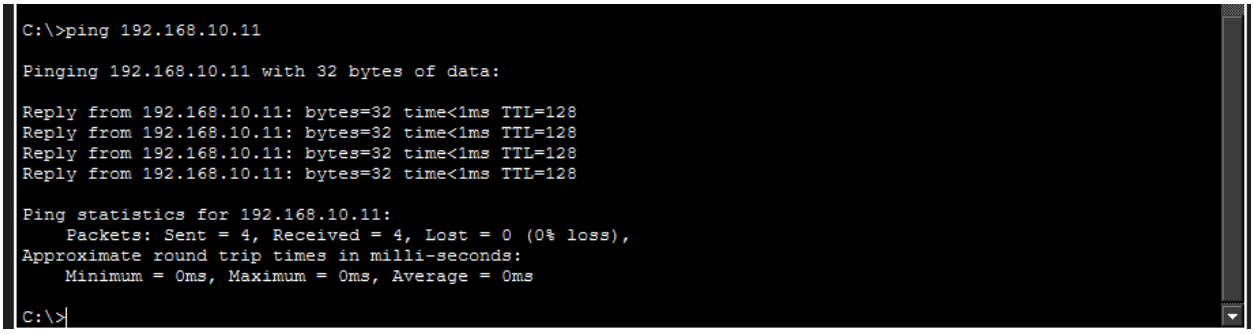


Figure 8: Test 4: HQ-PC1 -> HQ-PC2 (Same VLAN, Allowed)

Description: Successful ping between PCs in the same VLAN. Proves same-VLAN communication is unaffected by the ACL.

8.2 Member 1 — Configuration 2: SSH Secure Management (Free Choice)

- **Objective**: Establish SSHv2 for SW-Core using individual administrator user accounts. All connections through VTY ports should be made with SSH only. Telnet access will not be allowed.
- **Control Reference**: C08 - Centralized AAA
- **Threat Reference(s)**: T2 (Misuse of shared VPN credentials), T3 (Phishing/credential theft)
- **Device Type**: Cisco 3560 Multilayer Switch (SW-Core

Configuration Commands

```
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Switch(config)#
Switch(config)#! Step 1: Set hostname and domain name (required for RSA key generation)
Switch(config)#hostname SW-Core
SW-Core(config)#ip domain-name northbridge.local
SW-Core(config)#
SW-Core(config)#! Step 2: Generate RSA keys (1024-bit)
SW-Core(config)#crypto key generate rsa
The name for the keys will be: SW-Core.northbridge.local
Choose the size of the key modulus in the range of 360 to 2048 for your
  General Purpose Keys. Choosing a key modulus greater than 512 may take
  a few minutes.

How many bits in the modulus [512]: ! When prompted "How many bits in the modulus [512]:" type 1024 and press
Enter
% A decimal number between 360 and 2048
How many bits in the modulus [512]: % A decimal number between 360 and 2048
How many bits in the modulus [512]:
% Generating 512 bit RSA keys, keys will be non-exportable...[OK]

SW-Core(config)#! Step 3: Create admin user account
*Mar 3 16:1:9.584: RSA key size needs to be at least 768 bits for ssh version 2
*Mar 3 16:1:9.584: %SSH-5-ENABLED: SSH 1.5 has been enabled
SW-Core(config)#username admin privilege 15 secret Northbridge@2026
SW-Core(config)#
SW-Core(config)#! Step 4: Enable SSH version 2
SW-Core(config)#ip ssh version 2
Please create RSA keys (of at least 768 bits size) to enable SSH v2.
SW-Core(config)#
SW-Core(config)#! Step 5: Restrict VTY lines to SSH only
SW-Core(config)#line vty 0 4
SW-Core(config-line)# transport input ssh
SW-Core(config-line)# login local
SW-Core(config-line)#exit
SW-Core(config)#
SW-Core(config)#! Step 6: Set enable secret
SW-Core(config)#enable secret NorthbridgeEnable@2026
SW-Core(config)#
SW-Core(config)#! Step 7: Verify management SVI is up
SW-Core(config)#interface vlan 30
SW-Core(config-if)# ip address 192.168.30.1 255.255.255.0
SW-Core(config-if)# no shutdown
SW-Core(config-if)#exit
SW-Core(config)#
SW-Core(config)#end
SW-Core#write memory
%SYS-5-CONFIG_I: Configured from console by console

Building configuration...
[OK]
```

Figure 9: Commands used for SSH Configuration in SW-Core

Description: RSA key generation, creating user account, enabling SSH 2, and restrictions for VTY lines are shown. This proves that SSH Configuration was performed

```
SW-Core(config)#ip ssh version 2
*Mar 3 16:7:42.403: %SSH-5-ENABLED: SSH 1.99 has been enabled
SW-Core(config)#end
SW-Core#write memory
Building configuration...
[OK]
SW-Core#show ip ssh
%SYS-5-CONFIG_I: Configured from console by console

SSH Enabled - version 2.0
Authentication timeout: 120 secs; Authentication retries: 3
SW-Core#
```

Figure 10: show ip ssh output (SSH v2.0 enabled)

Description: It proves that SSH version 2.0 is configured (not v1.5). Proves that secure SSH is working.

```
SW-Core#show running-config | include transport input
 transport input ssh
```

Figure 11: VTY transport input SSH

Description: Transport input SSH on VTY lines is shown. Proves that Telnet is not allowed (only SSH).

```
SW-Core#show running-config | include username
username admin privilege 15 secret 5 $1$mERr$a5v7SOB9R7C8.x9JaJQxz.
SW-Core#
```

Figure 12: Creation of Admin user account

Description: Shows username admin privilege 15 secret line. Proves individual account exists (not shared). blocks direct DB access.

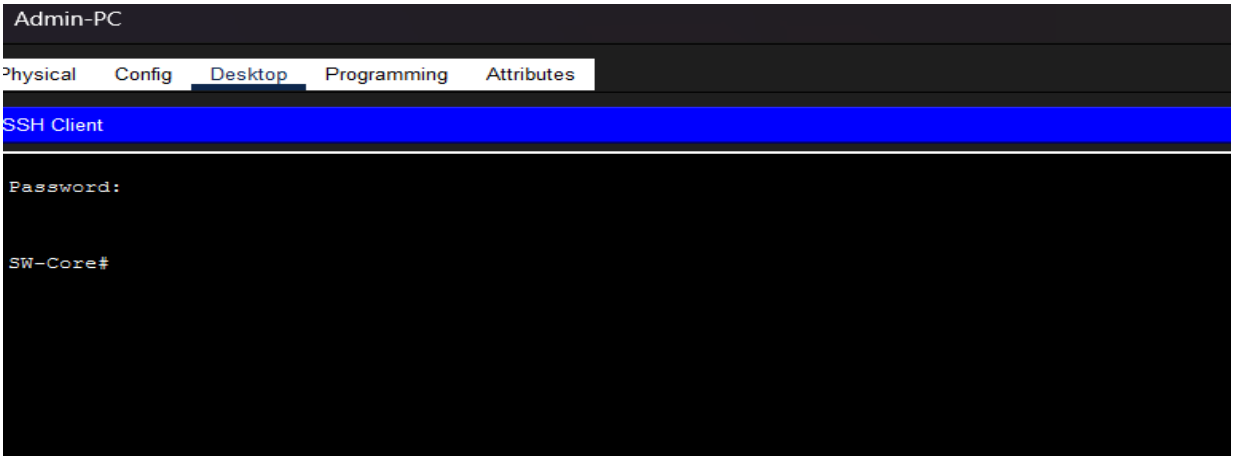


Figure 13: Successful SSH login from Admin-PC

Description: SSH connection to SW-Core with SW-Core> prompt is shown. Proves that SSH connection is working and Telnet is not working.



Figure 14: Attempted connection to Telnet failure

Description: SW-Core refuses connection to Telnet. Insecure Telnet is not permitted; only SSH is acceptable.

8.3 Member 2 — Configuration 1: Extended ACL on FW-PERIMETER (Plan-Linked)

- **Objective**: Implement extended ACL on FW-PERIMETER to manage traffic flow from the Internet, DMZ, and Internal network. Only allow necessary traffic to the DMZ; deny all other traffic.
- **Associated Control**: C02 - Next-Generation Firewall
- **Associated Threat(s)**: T1 (Ransomware), T4 (Third Party Compromise), T7 (Web Attack)
- **Device**: Cisco 2911 Router (FW-PERIMETER) acting as Firewall

Configuration Commands

```
FW-PERIMETER#configure terminal
FW-PERIMETER(config)#hostname FW-PERIMETER
FW-PERIMETER(config)#
FW-PERIMETER(config)#! Outside Interface (to ISP Router)
FW-PERIMETER(config)#interface GigabitEthernet1/1
FW-PERIMETER(config-if)# nameif outside
FW-PERIMETER(config-if)# security-level 0
FW-PERIMETER(config-if)# ip address 203.0.113.2 255.255.255.252
FW-PERIMETER(config-if)# no shutdown
FW-PERIMETER(config-if)#exit
FW-PERIMETER(config)#
FW-PERIMETER(config)#! DMZ Interface (to DMZ-SW)
FW-PERIMETER(config)#interface GigabitEthernet1/2
FW-PERIMETER(config-if)# nameif dmz
FW-PERIMETER(config-if)# security-level 50
FW-PERIMETER(config-if)# ip address 172.16.0.1 255.255.255.240
FW-PERIMETER(config-if)# no shutdown
FW-PERIMETER(config-if)#exit
FW-PERIMETER(config)#
FW-PERIMETER(config)#! Inside Interface (to FW-INTERNAL)
FW-PERIMETER(config)#interface GigabitEthernet1/3
FW-PERIMETER(config-if)# nameif inside
FW-PERIMETER(config-if)# security-level 100
FW-PERIMETER(config-if)# ip address 10.0.0.1 255.255.255.252
FW-PERIMETER(config-if)# no shutdown
FW-PERIMETER(config-if)#exit
FW-PERIMETER(config)#
FW-PERIMETER(config)#! ACL: Permit inbound HTTPS to Web Server
FW-PERIMETER(config)#access-list OUTSIDE_IN extended permit tcp any host 172.16.0.2 eq 443
FW-PERIMETER(config)#
FW-PERIMETER(config)#! ACL: Permit inbound SMTP to Payment Gateway
FW-PERIMETER(config)#access-list OUTSIDE_IN extended permit tcp any host 172.16.0.3 eq 25
FW-PERIMETER(config)#
FW-PERIMETER(config)#! ACL: Deny all other inbound traffic
FW-PERIMETER(config)#access-list OUTSIDE_IN extended deny ip any any log
```

```
FW-PERIMETER(config)#
FW-PERIMETER(config)#! Apply ACL to outside interface
FW-PERIMETER(config)#access-group OUTSIDE_IN in interface outside
FW-PERIMETER(config)#
FW-PERIMETER(config)#! ACL: Block DMZ from reaching internal network
FW-PERIMETER(config)#access-list DMZ_IN extended deny ip 172.16.0.0 255.255.255.240 192.168.0.0 255.255.0.0
FW-PERIMETER(config)#access-list DMZ_IN extended deny ip 172.16.0.0 255.255.255.240 10.0.0.0 255.255.255.0
FW-PERIMETER(config)#access-list DMZ_IN extended permit ip any any
WARNING: <DMZ_IN> found duplicate element
FW-PERIMETER(config)#
FW-PERIMETER(config)#access-group DMZ_IN in interface dmz
FW-PERIMETER(config)#
FW-PERIMETER(config)#! Routes
FW-PERIMETER(config)#route outside 0.0.0.0 0.0.0.0 203.0.113.1
FW-PERIMETER(config)#route inside 192.168.0.0 255.255.0.0 10.0.0.2
FW-PERIMETER(config)#route inside 10.1.0.0 255.255.0.0 10.0.0.2
FW-PERIMETER(config)#route inside 10.0.0.4 255.255.255.252 10.0.0.2
FW-PERIMETER(config)#
FW-PERIMETER(config)#! NAT
FW-PERIMETER(config)#object network INSIDE-NET
FW-PERIMETER(config-network-object)# subnet 10.0.0.0 255.255.255.252
FW-PERIMETER(config-network-object)# nat (inside,outside) dynamic interface
FW-PERIMETER(config-network-object)# nat (inside,dmz) dynamic interface
FW-PERIMETER(config-network-object)#
FW-PERIMETER(config-network-object)#object network DMZ-NET
FW-PERIMETER(config-network-object)# subnet 172.16.0.0 255.255.255.240
FW-PERIMETER(config-network-object)# nat (dmz,outside) dynamic interface
FW-PERIMETER(config-network-object)#
FW-PERIMETER(config-network-object)#! ICMP inspection
FW-PERIMETER(config-network-object)#policy-map global_policy
FW-PERIMETER(config-pmap)# class inspection_default
FW-PERIMETER(config-pmap-c)#  inspect icmp
FW-PERIMETER(config-pmap-c)#exit
FW-PERIMETER(config)#service-policy global_policy global
WARNING: Policy map global_policy is already configured as a service policy
FW-PERIMETER(config)#
FW-PERIMETER(config)#end
FW-PERIMETER#write memory
Building configuration...
Cryptochecksum: 65e577b5 23cd205d 219e7b24 06717461

2391  bytes copied in 2.912 secs (821 bytes/sec)
```

Figure 15: Extended ACL configuration on FW-PERIMETER

Description: The figure shows the IP addresses of all interfaces along with ACL configurations (OUTSIDE_IN & DMZ_IN) and static routes. It proves that the zone-based firewall rules have been set up successfully.

```
FW-PERIMETER#show interface ip brief
Interface              IP-Address      OK? Method Status                Protocol
Virtual0               127.1.0.1       YES unset  up                    up
GigabitEthernet1/1     203.0.113.2     YES manual up                    up
GigabitEthernet1/2     172.16.0.1      YES manual up                    up
GigabitEthernet1/3     10.0.0.1        YES manual up                    up
GigabitEthernet1/4     unassigned      YES unset  administratively down down
GigabitEthernet1/5     unassigned      YES unset  administratively down down
GigabitEthernet1/6     unassigned      YES unset  administratively down down
GigabitEthernet1/7     unassigned      YES unset  administratively down down
GigabitEthernet1/8     unassigned      YES unset  administratively down down
Management1/1          unassigned      YES unset  administratively down down
Internal-Control1/1    127.0.1.1       YES unset  up                    up
Internal-Data1/1       unassigned      YES unset  up                    up
Internal-Data1/2       unassigned      YES unset  up                    up
Internal-Data1/3       unassigned      YES unset  up                    up
```

Figure 16: show ip interface brief command output

Description: The figure shows all three interfaces (outside, dmz, and inside) are up/up with their respective IP addresses. It proves that all the firewall interfaces are functional.

```
FW-PERIMETER#show access-list
access-list cached ACL log flows: total 0, denied 0 (deny-flow-max 4096) alert-interval 300
access-list OUTSIDE_IN; 3 elements; name hash: 0x329db8d7
access-list OUTSIDE_IN line 1 extended permit icmp any any(hitcnt=0) 0x80e30b1d
access-list OUTSIDE_IN line 2 extended permit tcp any host 172.16.0.2 eq 443(hitcnt=0) 0xccbeb079
access-list OUTSIDE_IN line 3 extended permit tcp any host 172.16.0.3 eq smtp(hitcnt=0) 0xca0b5d6b
access-list INSIDE_IN; 2 elements; name hash: 0xb048eab1
access-list INSIDE_IN line 1 extended permit icmp any any(hitcnt=14) 0x1ddc13d1
access-list INSIDE_IN line 2 extended permit ip any any(hitcnt=0) 0x79bd1c1c
access-list DMZ_IN; 3 elements; name hash: 0x21a96baa
access-list DMZ_IN line 1 extended permit ip any any(hitcnt=2) 0x5d1d9d92
access-list DMZ_IN line 2 extended deny ip 172.16.0.0 255.255.255.240 192.168.0.0 255.255.0.0(hitcnt=0)
0x3193557c
access-list DMZ_IN line 3 extended deny ip 172.16.0.0 255.255.255.240 10.0.0.0 255.255.255.0(hitcnt=0)
0x3b17e0c4
```

Figure 17: show access-lists command output

Description: It lists the access lists OUTSIDE_IN (allows HTTPS & SMTP to DMZ and deny all others) and DMZ_IN (denies DMZ to Internal). This proves the correct configuration of access lists.

```
FW-PERIMETER#show route
Codes: C - connected, S - static, I - IGRP, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2, E - EGP
       i - IS-IS, L1 - IS-IS level-1, L2 - IS-IS level-2, ia - IS-IS inter area
       * - candidate default, U - per-user static route, o - ODR
       P - periodic downloaded static route

Gateway of last resort is 203.0.113.1 to network 0.0.0.0

     10.0.0.0/8 is variably subnetted, 3 subnets, 2 masks
C       10.0.0.0 255.255.255.252 is directly connected, inside, GigabitEthernet1/3
S       10.0.0.4 255.255.255.252 [1/0] via 10.0.0.2, inside
S       10.1.0.0 255.255.0.0 [1/0] via 10.0.0.2, inside
     172.16.0.0/28 is subnetted, 1 subnets
C       172.16.0.0 255.255.255.240 is directly connected, dmz, GigabitEthernet1/2
S    192.168.0.0 255.255.0.0 [1/0] via 10.0.0.2, inside
     203.0.113.0/30 is subnetted, 1 subnets
C       203.0.113.0 255.255.255.252 is directly connected, outside, GigabitEthernet1/1
S*   0.0.0.0/0 [1/0] via 203.0.113.1
```

Figure 18: show ip route command output

Description: It lists the routing table consisting of a default route for ISP along with static routes to internal networks. This proves the correct routing configuration.

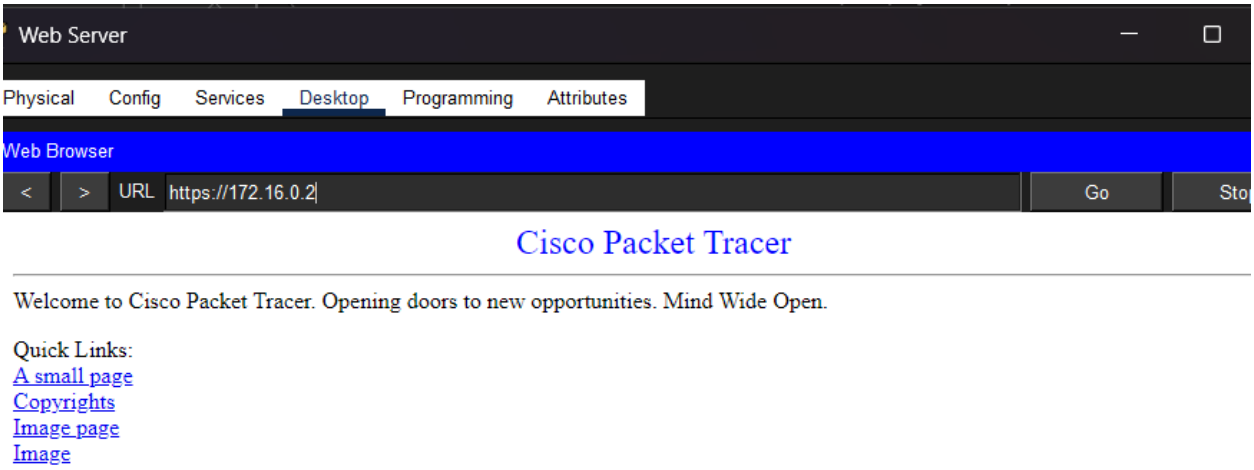


Figure 19: Test 1: HTTPS access to DMZ allowed

Description: The internet computer accesses the Web Server using HTTPS protocol. Demonstrates that inbound HTTPS to the DMZ is allowed.

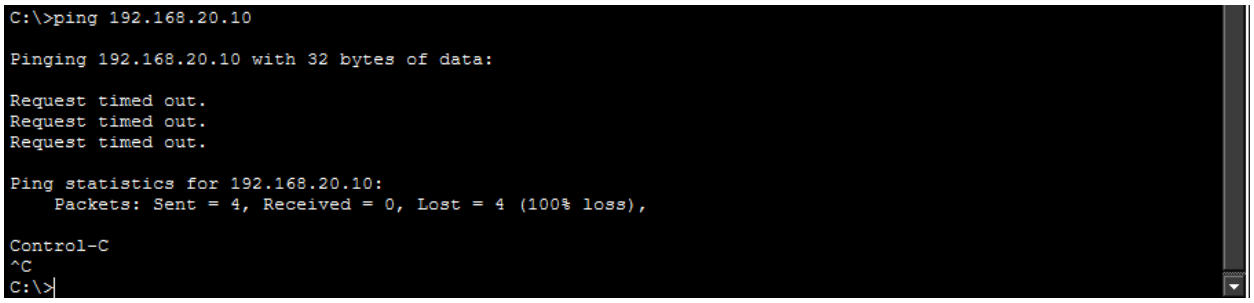


Figure 20: Test 3: DMZ -> Internal blocked

Description: Ping from the Web Server to the internal IP address 192.168.20.10 times out. This proves that the DMZ cannot pivot into the internal network even if it gets compromised.

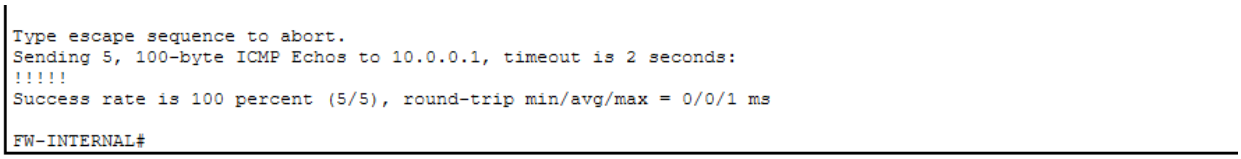


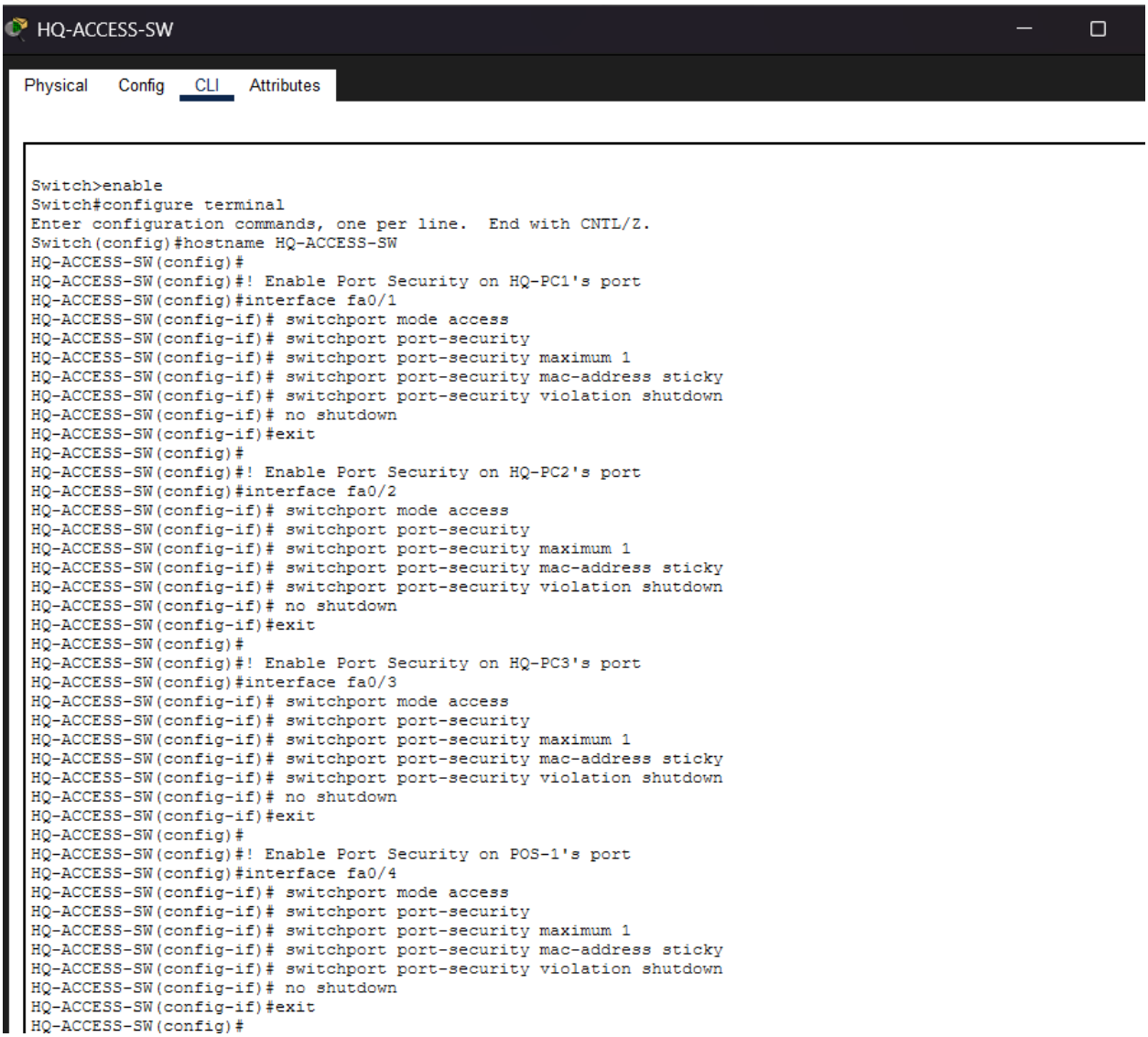
Figure 21: Test 4: FW-PERIMETER -> FW-INTERNAL link works

Description: Successful ping from FW-INTERNAL to FW-PERIMETER (10.0.0.1). Five out of five responses are

8.4 Member 2 — Configuration 2: Port Security on Access Switch (Free Choice)

- **Objective**: To provide Port Security on HQ-ACCESS-SW such that certain switch ports can be restricted from allowing connection by unauthorized devices via their MAC addresses. The unauthorized device leads to port disablement.
- **Associated Control**: C06 - Endpoint Security Management (NAC)
- **Associated Threat(s):** T1 - Ransomware, T8 - BYOD
- **Equipment**: Cisco 2960 Access Switch (HQ-ACCESS-SW)

Configuration Commands



```
HQ-ACCESS-SW(config)#! Enable Port Security on Admin-PC's port
HQ-ACCESS-SW(config)#interface fa0/9
HQ-ACCESS-SW(config-if)# switchport mode access
HQ-ACCESS-SW(config-if)# switchport port-security
HQ-ACCESS-SW(config-if)# switchport port-security maximum 1
HQ-ACCESS-SW(config-if)# switchport port-security mac-address sticky
HQ-ACCESS-SW(config-if)# switchport port-security violation shutdown
HQ-ACCESS-SW(config-if)# no shutdown
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#end
HQ-ACCESS-SW#write memory
%SYS-5-CONFIG_I: Configured from console by console

Building configuration...
[OK]
HQ-ACCESS-SW#
```

Figure 22: Port Security configuration on HQ-ACCESS-SW

Description: Displays the configuration of port-security on Fa0/1, Fa0/2, Fa0/3, Fa0/9 using max 1 MAC, sticky learning and shutdown violation mode. It confirms that the configuration is complete.

```
HQ-ACCESS-SW#show port-security
Secure Port MaxSecureAddr CurrentAddr SecurityViolation Security Action
               (Count)       (Count)        (Count)
------------------------------------------------------------------------
        Fa0/1        1          0                0         Shutdown
        Fa0/2        1          0                0         Shutdown
        Fa0/3        1          0                0         Shutdown
        Fa0/4        1          0                0         Shutdown
        Fa0/9        1          0                0         Shutdown
------------------------------------------------------------------------
HQ-ACCESS-SW#show port-security interface fa0/1
Port Security              : Enabled
Port Status                : Secure-up
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 0
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 0
Last Source Address:Vlan   : 0000.0000.0000:0
Security Violation Count   : 0
```

Figure 23: show port-security summary

Description: Provides the list of all secure ports (Fa0/1, Fa0/2, Fa0/3, Fa0/9) having Secure-up status and 0 violations. It confirms that port security is configured for all client ports.

```
HQ-ACCESS-SW#show port-security address
               Secure Mac Address Table
------------------------------------------------------------------------
Vlan    Mac Address       Type                          Ports   Remaining Age
                                                                    (mins)
----    -----------       ----                          -----   -------------
------------------------------------------------------------------------
Total Addresses in System (excluding one mac per port)     : 0
Max Addresses limit in System (excluding one mac per port) : 1024
HQ-ACCESS-SW#show interfaces status
Port      Name               Status       Vlan       Duplex  Speed Type
Fa0/1                        connected    10         a-full  a-100 10/100BaseTX
Fa0/2                        connected    10         a-full  a-100 10/100BaseTX
Fa0/3                        connected    10         a-full  a-100 10/100BaseTX
Fa0/4                        connected    30         a-full  a-100 10/100BaseTX
Fa0/5                        connected    30         a-full  a-100 10/100BaseTX
Fa0/6                        connected    30         a-full  a-100 10/100BaseTX
Fa0/7                        connected    trunk      a-full  a-100 10/100BaseTX
Fa0/8                        connected    trunk      a-full  a-100 10/100BaseTX
Fa0/9                        connected    30         a-full  a-100 10/100BaseTX
Fa0/10                       notconnect   1          auto    auto  10/100BaseTX
Fa0/11                       notconnect   1          auto    auto  10/100BaseTX
Fa0/12                       notconnect   1          auto    auto  10/100BaseTX
Fa0/13                       notconnect   1          auto    auto  10/100BaseTX
Fa0/14                       notconnect   1          auto    auto  10/100BaseTX
Fa0/15                       notconnect   1          auto    auto  10/100BaseTX
Fa0/16                       notconnect   1          auto    auto  10/100BaseTX
Fa0/17                       notconnect   1          auto    auto  10/100BaseTX
Fa0/18                       notconnect   1          auto    auto  10/100BaseTX
Fa0/19                       notconnect   1          auto    auto  10/100BaseTX
Fa0/20                       notconnect   1          auto    auto  10/100BaseTX
Fa0/21                       notconnect   1          auto    auto  10/100BaseTX
Fa0/22                       notconnect   1          auto    auto  10/100BaseTX
Fa0/23                       notconnect   1          auto    auto  10/100BaseTX
Fa0/24                       notconnect   1          auto    auto  10/100BaseTX
Gig0/1                       connected    trunk      a-full  a-100 10/100/1000BaseTX
Gig0/2                       notconnect   trunk      auto    auto  10/100/1000BaseTX

HQ-ACCESS-SW#
HQ-ACCESS-SW#
```

Figure 24: show port-security interface fa0/1 detail

Description: Provides information about Port Status = Secure-up, Violation Mode = Shutdown, Max MAC = 1, and Sticky MAC learned from HQ-PC1. It confirms that the port is learning the authorized device.

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time=1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\>
```

Figure 25: Authorized connectivity between PC and Application Server (HQ-PC1 -> App Server)

Description: Ping between HQ-PC1 and App Server succeeded. There are 4 replies. Indicates that port security did not block authorized connections.

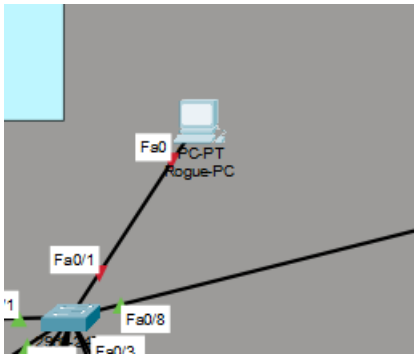


Figure 26: Violation caused by Rogue-PC

```
HQ-ACCESS-SW#show port-security interface fa0/1
Port Security              : Enabled
Port Status                : Secure-shutdown
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 1
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 1
Last Source Address:Vlan   : 0001.43A5.7EC7:10
Security Violation Count   : 1

HQ-ACCESS-SW#
```

Description: Once Rogue-PC connected to Fa0/1, show port security fa0/1 output shows Secure-shutdown and Violation count equals 1. This indicates that an unauthorized device triggered the shutdown.

```
HQ-ACCESS-SW#show interfaces status
Port      Name               Status       Vlan       Duplex  Speed Type
Fa0/1                        err-disabled 10         auto    auto  10/100BaseTX
Fa0/2                        connected    10         a-full  a-100 10/100BaseTX
Fa0/3                        connected    10         a-full  a-100 10/100BaseTX
Fa0/4                        connected    30         a-full  a-100 10/100BaseTX
Fa0/5                        connected    30         a-full  a-100 10/100BaseTX
Fa0/6                        connected    30         a-full  a-100 10/100BaseTX
Fa0/7                        connected    trunk      a-full  a-100 10/100BaseTX
Fa0/8                        connected    trunk      a-full  a-100 10/100BaseTX
Fa0/9                        connected    30         a-full  a-100 10/100BaseTX
Fa0/10                       notconnect   1          auto    auto  10/100BaseTX
Fa0/11                       notconnect   1          auto    auto  10/100BaseTX
Fa0/12                       notconnect   1          auto    auto  10/100BaseTX
Fa0/13                       notconnect   1          auto    auto  10/100BaseTX
Fa0/14                       notconnect   1          auto    auto  10/100BaseTX
Fa0/15                       notconnect   1          auto    auto  10/100BaseTX
Fa0/16                       notconnect   1          auto    auto  10/100BaseTX
Fa0/17                       notconnect   1          auto    auto  10/100BaseTX
Fa0/18                       notconnect   1          auto    auto  10/100BaseTX
Fa0/19                       notconnect   1          auto    auto  10/100BaseTX
Fa0/20                       notconnect   1          auto    auto  10/100BaseTX
Fa0/21                       notconnect   1          auto    auto  10/100BaseTX
Fa0/22                       notconnect   1          auto    auto  10/100BaseTX
Fa0/23                       notconnect   1          auto    auto  10/100BaseTX
Fa0/24                       notconnect   1          auto    auto  10/100BaseTX
Gig0/1                       connected    trunk      a-full  a-100 10/100/1000BaseTX
Gig0/2                       notconnect   trunk      auto    auto  10/100/1000BaseTX

HQ-ACCESS-SW#
HQ-ACCESS-SW#
```

Figure 27: Figure 9.29 — Port status err-disabled

Description: The command shows interfaces status shows that Fa0/1 is err-disabled. Indicates that the port is totally shut down after violation.

8.5 Member 3 - Configuration 1: Inter-VLAN ACL on SW-Core (Plan-Linked)

- **Objective**: Implement an extended ACL on SW-Core to define zone-based rules for traffic flow between User, Server, and Guest VLANs. Limits the User zone to certain services and blocks the Guest zone completely within internal networks.
- **Associated Control:** C02 – Next-Generation Firewall
- **Associated Threat(s):** T1, T4, T5, T8
- **Device**: Cisco 3560 Multilayer Switch (SW-Core)

Configuration Commands

```
SW-Core>enable
Password:
SW-Core#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
SW-Core(config)#
SW-Core(config)#! Create ACL that permits User Zone to reach ONLY the App Server
SW-Core(config)#ip access-list extended USERS_TO_SERVERS
SW-Core(config-ext-nacl)# permit icmp 192.168.10.0 0.0.0.255 host 192.168.20.10
SW-Core(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 443
SW-Core(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 3389
SW-Core(config-ext-nacl)# deny ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
SW-Core(config-ext-nacl)# permit ip any any
SW-Core(config-ext-nacl)#exit
SW-Core(config)#
SW-Core(config)#! Create ACL that blocks Guest Zone from reaching internal zones
SW-Core(config)#ip access-list extended GUEST_DENY
SW-Core(config-ext-nacl)# deny ip 192.168.40.0 0.0.0.255 192.168.10.0 0.0.0.255
SW-Core(config-ext-nacl)# deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255
SW-Core(config-ext-nacl)# deny ip 192.168.40.0 0.0.0.255 192.168.30.0 0.0.0.255
SW-Core(config-ext-nacl)# permit ip any any
SW-Core(config-ext-nacl)#exit
SW-Core(config)#
SW-Core(config)#! Apply USER ACL to User VLAN SVI
SW-Core(config)#interface vlan 10
SW-Core(config-if)# ip access-group USERS_TO_SERVERS in
SW-Core(config-if)#exit
SW-Core(config)#
SW-Core(config)#! Apply GUEST ACL to Guest VLAN SVI
SW-Core(config)#interface vlan 40
SW-Core(config-if)# ip access-group GUEST_DENY in
SW-Core(config-if)#exit
SW-Core(config)#
SW-Core(config)#end
SW-Core#write memory
%SYS-5-CONFIG_I: Configured from console by console

Building configuration...
[OK]
SW-Core#
```

Figure 28: Inter-VLAN ACL configuration on SW-Core

Description: Illustrates that USERS_TO_SERVERS and GUEST_DENY ACLs have been configured on VLAN 10 and VLAN 40 SVIs. Shows the existence of zone-based filtering.

```
SW-Core#show access-lists
Extended IP access list GUEST_DENY
    10 deny ip 192.168.40.0 0.0.0.255 192.168.10.0 0.0.0.255
    20 deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255
    30 deny ip 192.168.40.0 0.0.0.255 192.168.30.0 0.0.0.255
    40 permit ip any any
Extended IP access list USERS_TO_SERVERS
    10 permit icmp 192.168.10.0 0.0.0.255 host 192.168.20.10
    20 permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 443
    30 permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 3389
    40 deny ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255 (4 match(es))
    50 permit ip any any
```

Figure 29: Output of show access-lists command

Description: Displays both ACLs along with their rules and hitcnt. Shows that ACLs are currently matching traffic.

```
SW-Core#show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
FastEthernet0/1        10.0.0.6        YES manual up                    up
FastEthernet0/2        unassigned      YES unset  up                    up
FastEthernet0/3        unassigned      YES unset  up                    up
FastEthernet0/4        unassigned      YES unset  down                  down
FastEthernet0/5        unassigned      YES unset  down                  down
FastEthernet0/6        unassigned      YES unset  down                  down
FastEthernet0/7        unassigned      YES unset  down                  down
FastEthernet0/8        unassigned      YES unset  down                  down
FastEthernet0/9        unassigned      YES unset  down                  down
FastEthernet0/10       unassigned      YES unset  down                  down
FastEthernet0/11       unassigned      YES unset  down                  down
FastEthernet0/12       unassigned      YES unset  down                  down
FastEthernet0/13       unassigned      YES unset  down                  down
FastEthernet0/14       unassigned      YES unset  down                  down
FastEthernet0/15       unassigned      YES unset  down                  down
FastEthernet0/16       unassigned      YES unset  down                  down
FastEthernet0/17       unassigned      YES unset  down                  down
FastEthernet0/18       unassigned      YES unset  down                  down
FastEthernet0/19       unassigned      YES unset  down                  down
FastEthernet0/20       unassigned      YES unset  down                  down
FastEthernet0/21       unassigned      YES unset  down                  down
```

Figure 30: Output of show ip interface brief command

Description: shows all SVIs up/up with IP addresses assigned. Shows that all VLAN interfaces are up for inter-VLAN routing.

```
SW-Core#show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/5, Fa0/6, Fa0/7, Fa0/8
                                                Fa0/9, Fa0/10, Fa0/11, Fa0/12
                                                Fa0/13, Fa0/14, Fa0/15, Fa0/16
                                                Fa0/17, Fa0/18, Fa0/19, Fa0/20
                                                Fa0/21, Fa0/22, Fa0/23, Fa0/24
                                                Gig0/1, Gig0/2
10   USERS                            active
11   BRANCH1                          active
12   BRANCH2                          active
13   BRANCH3                          active
14   BRANCH4                          active
15   BRANCH5                          active
16   BRANCH6                          active
20   SERVERS                          active
30   MANAGEMENT                       active
40   GUEST                            active    Fa0/4
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
```

Snipping Tool

Figure 31: Output of show vlan brief command

Description: Shows all VLANs are active. Shows the presence of VLAN segmentation before configuring ACLs.

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time=1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\>
```

Figure 32: Test 1: User -> App Server (allowed)

Description: Successful ping from HQ-PC1 to App Server. Confirms that ACL allows allowed business traffic.

```
C:\>ping 192.168.20.11

Pinging 192.168.20.11 with 32 bytes of data:

Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.
Reply from 192.168.10.1: Destination host unreachable.

Ping statistics for 192.168.20.11:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

Figure 33: Test 2: User -> DB Server (blocked)

Description: Ping from HQ-PC1 to DB Server results in “Destination host unreachable” or “Request timed out.” Confirms that DB access is restricted.

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Request timed out.
Request timed out.

Ping statistics for 192.168.20.10:
    Packets: Sent = 3, Received = 0, Lost = 3 (100% loss),

Control-C
^C
C:\>
```

Figure 34: Test 3: Guest -> App Server (blocked)

Description: Ping from Guest PC to App Server results in request timeout. Confirms that guest zone cannot communicate with internal servers.

```
C:\>
ping 192.168.40.10

Pinging 192.168.40.10 with 32 bytes of data:

Reply from 192.168.40.10: bytes=32 time=177ms TTL=128
Reply from 192.168.40.10: bytes=32 time=81ms TTL=128
Reply from 192.168.40.10: bytes=32 time=62ms TTL=128
Reply from 192.168.40.10: bytes=32 time=114ms TTL=128

Ping statistics for 192.168.40.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 62ms, Maximum = 177ms, Average = 108ms

C:\>
```

Figure 35: Test 4: Guest -> Guest (same VLAN, allowed)

Description: Ping from one Guest PC (192.168.40.10) to another Guest PC (192.168.40.11) successfully performed. Total replies received.

8.6 Member 3 - Configuration 2: DHCP Snooping on Access Switch (Free Choice)

- **Objective**: Activate the DHCP Snooping feature on HQ-ACCESS-SW in order to avoid any unauthorized IP configuration by DHCP servers. Trusted ports (uplink ports) are identified; Untrusted ports (client ports) are rate limited.
- **Control Related:** C05 - IDS/IPS
- **Threats Related**: T1 (Ransomware by MITM), T8 (BYOD)
- **Device**: Cisco 2960 Access Switch

Configuration Commands

```
HQ-ACCESS-SW>enable
HQ-ACCESS-SW#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
HQ-ACCESS-SW(config)#hostname HQ-ACCESS-SW
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#! Enable DHCP Snooping globally
HQ-ACCESS-SW(config)#ip dhcp snooping
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#! Enable DHCP Snooping for VLANs 10, 20, 30, 40
HQ-ACCESS-SW(config)#ip dhcp snooping vlan 10,20,30,40
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#! Configure trusted uplink port (towards the legitimate DHCP server)
HQ-ACCESS-SW(config)#interface Gig0/1
HQ-ACCESS-SW(config-if)# ip dhcp snooping trust
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#! Configure untrusted ports for clients (rate-limit DHCP packets)
HQ-ACCESS-SW(config)#interface fa0/1
HQ-ACCESS-SW(config-if)# ip dhcp snooping limit rate 10
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#interface fa0/2
HQ-ACCESS-SW(config-if)# ip dhcp snooping limit rate 10
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#interface fa0/3
HQ-ACCESS-SW(config-if)# ip dhcp snooping limit rate 10
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#interface fa0/4
HQ-ACCESS-SW(config-if)# ip dhcp snooping limit rate 10
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#interface fa0/9
HQ-ACCESS-SW(config-if)# ip dhcp snooping limit rate 10
HQ-ACCESS-SW(config-if)#exit
HQ-ACCESS-SW(config)#
HQ-ACCESS-SW(config)#end
HQ-ACCESS-SW#write memory
%SYS-5-CONFIG_I: Configured from console by console

Building configuration...
[OK]
```

Figure 36: DHCP Snooping configuration on HQ-ACCESS-SW

Description: Demonstrates global DHCP snooping configuration with trusted uplink and rate-limited client ports on VLANs 10-40. This proves that configuration is correct.

```
HQ-ACCESS-SW#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
10,20,30,40
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                  Trusted    Rate limit (pps)
-----------------------    -------    ----------------
FastEthernet0/2            no         10
FastEthernet0/1            no         10
FastEthernet0/4            no         10
FastEthernet0/3            no         10
FastEthernet0/9            no         10
GigabitEthernet0/1         yes        unlimited
HQ-ACCESS-SW#
```

Figure 37: show ip dhcp snooping command output

Description: Indicates DHCP snooping configured correctly and includes ports' status as trusted and untrusted ports. It proves that the function is activated.

```
HQ-ACCESS-SW>enable
HQ-ACCESS-SW#show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  ------------------
Total number of bindings: 0
```

Figure 38: show ip dhcp snooping binding command output

Description: Displays binding table with "Total number of bindings: 0" because all test PCs are using static IPs. The configuration has proved to be activated.

- The binding table of DHCP Snooping is empty since in the lab scenario static IP allocation has been used for all the test PCs. For DHCP clients, the table will be filled by default when clients send lease requests to the DHCP server. The configuration is checked as enabled using

8.7 Member 4 — Configuration 1: Dynamic ARP Inspection on SW-Core (Plan-Linked)

- **Objective**: Enable Dynamic ARP Inspection (DAI) on SW-Core to protect against ARP spoofing attacks. DAI checks whether the ARP packets are valid based on the DHCP snooping binding table and drops invalid ARP packets.
- **Control Associated**: C05 - IDS/IPS
- **Threats Affected**: T1 (Ransomware through MITM attack), T8 (BYOD)
- **Equipment**: Cisco 3560 Multilayer Switch (SW-Core)

Configuration Commands

```
SW-Core#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
SW-Core(config)#
SW-Core(config)#! DHCP Snooping for DAI binding source
SW-Core(config)#ip dhcp snooping
SW-Core(config)#ip dhcp snooping vlan 10,20,30,40
SW-Core(config)#
SW-Core(config)#! Trust the Layer 2 uplinks only (Fa0/2, Fa0/3 are switchports)
SW-Core(config)#interface Fa0/2
SW-Core(config-if)# ip dhcp snooping trust
SW-Core(config-if)#exit
SW-Core(config)#interface Fa0/3
SW-Core(config-if)# ip dhcp snooping trust
SW-Core(config-if)#exit
SW-Core(config)#
SW-Core(config)#! Enable DAI on internal VLANs
SW-Core(config)#ip arp inspection vlan 10,20,30,40
SW-Core(config)#
SW-Core(config)#! Trust uplinks for ARP (Fa0/1 works even as routed port)
SW-Core(config)#interface Fa0/1
SW-Core(config-if)# ip arp inspection trust
SW-Core(config-if)#exit
SW-Core(config)#interface Fa0/2
SW-Core(config-if)# ip arp inspection trust
SW-Core(config-if)#exit
SW-Core(config)#interface Fa0/3
SW-Core(config-if)# ip arp inspection trust
SW-Core(config-if)#exit
SW-Core(config)#
SW-Core(config)#end
SW-Core#write memory
%SYS-5-CONFIG_I: Configured from console by console

Building configuration...
[OK]
SW-Core#
```

Figure 39: Configuration of DAI on SW-Core

Description: Indicates DHCP snooping is enabled, DAI is enabled on VLANs 10-40, and uplink ports are set as trusted. DAI is properly configured.

```
SW-Core#show ip arp inspection vlan 10

Source Mac Validation      : Disabled
Destination Mac Validation : Disabled
IP Address Validation      : Disabled

 Vlan     Configuration    Operation   ACL Match          Static ACL
 ----     -------------    ---------   ---------          ----------
   10     Enabled          Active

 Vlan     ACL Logging      DHCP Logging      Probe Logging
 ----     -----------      ------------      -------------
   10     Deny             Deny              Off
```

Figure 40: Output of command show ip arp inspection vlan 10

Description: Displays that "Configuration: Enabled, Operation: Active" for VLAN 10. It shows that DAI is enabled on the VLAN.

```
SW-Core#show ip arp inspection interfaces
Interface        Trust State     Rate (pps)     Burst Interval
---------------  -----------     ----------     --------------
Fa0/1            Trusted                 15                  1
Fa0/2            Trusted                 15                  1
Fa0/3            Trusted                 15                  1
Fa0/4            Untrusted               15                  1
Fa0/5            Untrusted               15                  1
Fa0/6            Untrusted               15                  1
Fa0/7            Untrusted               15                  1
Fa0/8            Untrusted               15                  1
Fa0/9            Untrusted               15                  1
Fa0/10           Untrusted               15                  1
Fa0/11           Untrusted               15                  1
Fa0/12           Untrusted               15                  1
Fa0/13           Untrusted               15                  1
Fa0/14           Untrusted               15                  1
Fa0/15           Untrusted               15                  1
Fa0/16           Untrusted               15                  1
Fa0/17           Untrusted               15                  1
Fa0/18           Untrusted               15                  1
Fa0/19           Untrusted               15                  1
Fa0/20           Untrusted               15                  1
```

Figure 41: Output of command show ip arp inspection interfaces

Description: Lists interfaces with Trust state (uplink interface as trusted and client interface as untrusted). Correct trust designations are confirmed.

```
SW-Core#show ip arp inspection statistics

 Vlan      Forwarded        Dropped     DHCP Drops     ACL Drops
 ----      ---------        -------     ----------     ---------
   10              0              0              0             0
   20              0              0              0             0
   30              2              0              0             0
   40              0              0              0             0

 Vlan   DHCP Permits    ACL Permits   Source MAC Failures
 ----   ------------    -----------   -------------------
   10              0              0                     0
   20              0              0                     0
   30              2              0                     0
   40              0              0                     0

 Vlan   Dest MAC Failures   IP Validation Failures
 ----   -----------------   ----------------------
   10                   0                       0
   20                   0                       0
   30                   0                       0
   40                   0                       0

SW-Core#
```

Figure 42: Output of command show ip arp inspection statistics

Description: Displays counters for forwarded/dropped ARP traffic per VLAN. Counter of VLAN 30 equal to 2 indicates that DAI is active.

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time=1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127
Reply from 192.168.20.10: bytes=32 time<1ms TTL=127

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms
```

Figure 43: Valid ARP request is not blocked (from HQ-PC1 to App Server)

Description: Successful ping from HQ-PC1 to App Server with 4/4 replies.

8.8 Member 4 — Configuration 2: AAA Local Authentication (Free Choice)

- **Objective:** To enable AAA for FW-PERIMETER using user accounts (admin1, admin2, auditor) to allow accountability and secure SSH connection.
- **Corresponding Control:** C03 (MFA), C08 (AAA)
- **Corresponding Threats:** T2 (Abuse of shared VPN account), T5 (Insider threat)
- **Device**: Cisco ASA 5506-X (FW -PERIMETER)

Configuration Commands

```
FW-PERIMETER>enable
Password:
FW-PERIMETER#configure terminal
FW-PERIMETER(config)#! Create local users (ASA syntax: password, not secret)
FW-PERIMETER(config)#username admin1 password Admin1@Northbridge privilege 15
                                                                 ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#username admin2 password Admin2@Northbridge privilege 5
                                                                 ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#username auditor password Auditor@Northbridge privilege 1
                                                                   ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#
FW-PERIMETER(config)#! Enable AAA for SSH access
FW-PERIMETER(config)#aaa authentication ssh console LOCAL
FW-PERIMETER(config)#aaa authentication enable console LOCAL
                                       ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#aaa authorization command LOCAL
                         ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#aaa accounting command LOCAL
                          ^
% Invalid input detected at '^' marker.

FW-PERIMETER(config)#
FW-PERIMETER(config)#! Enable SSH access on the inside interface
FW-PERIMETER(config)#ssh 10.0.0.0 255.255.255.0 inside
FW-PERIMETER(config)#ssh timeout 10
FW-PERIMETER(config)#
FW-PERIMETER(config)#end
FW-PERIMETER#write memory
```

```
FW-PERIMETER(config)#
FW-PERIMETER(config)#username admin1 password Admin1Pass
FW-PERIMETER(config)#username admin2 password Admin2Pass
FW-PERIMETER(config)#username auditor password AuditorPas
FW-PERIMETER(config)#
```

Figure 44: Commands associated with AAA Configuration on FW-PERIMETER

Description: Demonstrates the three commands with usernames (admin1, admin2, auditor), AAA authentication ssh console LOCAL, and ssh 10.0.0.0 … inside. This is proof that the AAA configuration and SSH access is set up.

```
FW-PERIMETER#show running-config | include username
username admin1 password 3gKAMEqqqPjxayMf encrypted
username admin2 password 0zgOvmXXEwwR8DYp encrypted
username auditor password TGEbyJ2mEjJc5w0B encrypted
```

Figure 45: Output of running-config | include username command

Description: This is where the three user accounts are seen with encrypted passwords. Proof that individual accounts exist with separate credentials.

```
FW-PERIMETER#show running-config | include aaa
aaa authentication ssh console LOCAL
```

Figure 46: Output of running-config | include AAA command

Description: This shows the use of AAA authentication ssh console LOCAL. This is proof that AAA is used to authenticate SSH locally.

```
FW-PERIMETER#show running-config | include ssh
aaa authentication ssh console LOCAL
ssh 10.0.0.0 255.255.255.0 inside
ssh timeout 10
```

Figure 47: Output of running-config | include ssh command

Description: The output demonstrates the use of ssh 10.0.0.0 255.255.25

```
FW-PERIMETER#show running-config
ASA Version 9.6(1)
!
hostname FW-PERIMETER
names
!
interface GigabitEthernet1/1
 nameif outside
 security-level 0
 ip address 203.0.113.2 255.255.255.252
!
interface GigabitEthernet1/2
 nameif dmz
 security-level 50
 ip address 172.16.0.1 255.255.255.240
!
interface GigabitEthernet1/3
 nameif inside
 security-level 100
 ip address 10.0.0.1 255.255.255.252
!
interface GigabitEthernet1/4
 no nameif
 no security-level
 no ip address
 shutdown
!
interface GigabitEthernet1/5
 no nameif
 no security-level
 no ip address
 shutdown
!
interface GigabitEthernet1/6
 no nameif
 no security-level
 no ip address
 shutdown
!
interface GigabitEthernet1/7
 no nameif
 no security-level
 no ip address
 shutdown
!
interface GigabitEthernet1/8
 no nameif
 no security-level
```

Snipping Tool

Screenshot copied to clipboard

```
 no nameif
 no security-level
 no ip address
 shutdown
!
interface GigabitEthernet1/8
 no nameif
 no security-level
 no ip address
 shutdown
!
interface Management1/1
 management-only
 no nameif
 no security-level
 no ip address
 shutdown
!
object network BRANCH-NET
 subnet 10.1.0.0 255.255.0.0
 nat (inside,dmz) dynamic interface
object network DMZ-NET
 subnet 172.16.0.0 255.255.255.240
 nat (dmz,outside) dynamic interface
object network FW-LINK
 subnet 10.0.0.0 255.255.255.252
 nat (inside,dmz) dynamic interface
object network INSIDE-NET
 subnet 10.0.0.0 255.255.255.252
 nat (inside,dmz) dynamic interface
object network INTERNAL-NET
 subnet 192.168.0.0 255.255.0.0
 nat (inside,dmz) dynamic interface
!
route outside 0.0.0.0 0.0.0.0 203.0.113.1 1
route inside 192.168.0.0 255.255.0.0 10.0.0.2 1
route inside 10.1.0.0 255.255.0.0 10.0.0.2 1
route inside 10.0.0.4 255.255.255.252 10.0.0.2 1
!
access-list OUTSIDE_IN extended permit icmp any any
access-list OUTSIDE_IN extended permit tcp any host 172.16.0.2 eq 443
access-list OUTSIDE_IN extended permit tcp any host 172.16.0.3 eq smtp
access-list INSIDE_IN extended permit icmp any any
access-list INSIDE_IN extended permit ip any any
access-list DMZ_IN extended permit ip any any
access-list DMZ_IN extended deny ip 172.16.0.0 255.255.255.240 192.168.0.0 255.255.0.0
access-list DMZ_IN extended deny ip 172.16.0.0 255.255.255.240 10.0.0.0 255.255.255.0
!
!
access-group INSIDE_IN in interface inside
access-group DMZ_IN in interface dmz
access-group OUTSIDE_IN in interface outside
```

```
access-group INSIDE_IN in interface inside
access-group DMZ_IN in interface dmz
access-group OUTSIDE_IN in interface outside
aaa authentication ssh console LOCAL
!
username admin1 password 3gKAMEqqqPjxayMf encrypted
username admin2 password 0zgOvmXXEwwR8DYp encrypted
username auditor password TGEbyJ2mEjJc5w0B encrypted
!
class-map inspection_default
 match default-inspection-traffic
!
policy-map type inspect dns preset_dns_map
 parameters
  message-length maximum 512
policy-map global_policy
 class inspection_default
  inspect http
  inspect icmp
!
service-policy global_policy global
!
telnet timeout 5
ssh 10.0.0.0 255.255.255.0 inside
ssh timeout 10
!
!
!
!
FW-PERIMETER#
FW-PERIMETER#
FW-PERIMETER#
```

Snipping Tool

Screenshot copied to clipboard

Figure 48: show running config

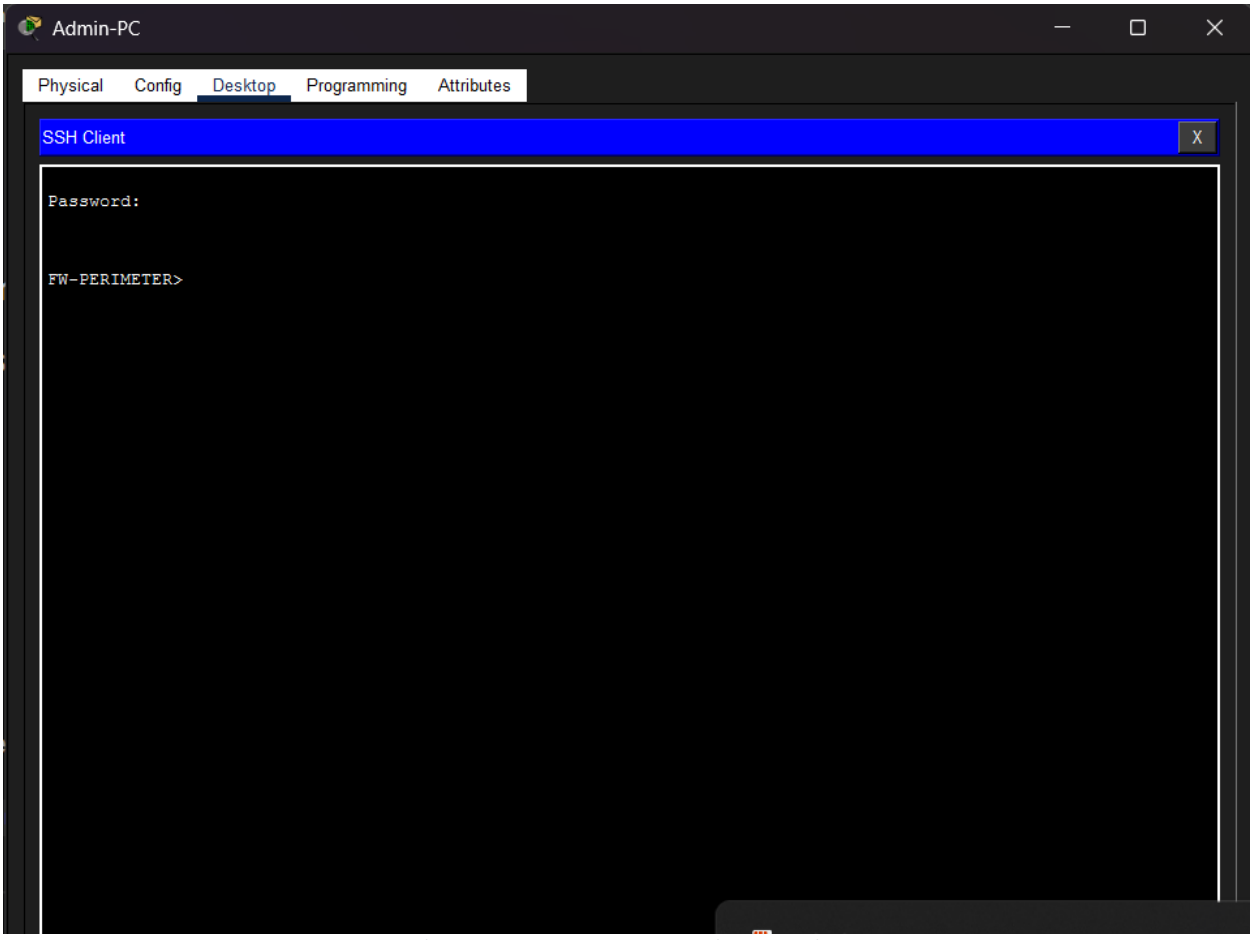


Figure 49: Successful SSH login as admin1

Description: SSH connection logged in as admin1 with prompt for FW-PERIMETER shown. Indicates that individual user authentication is working.

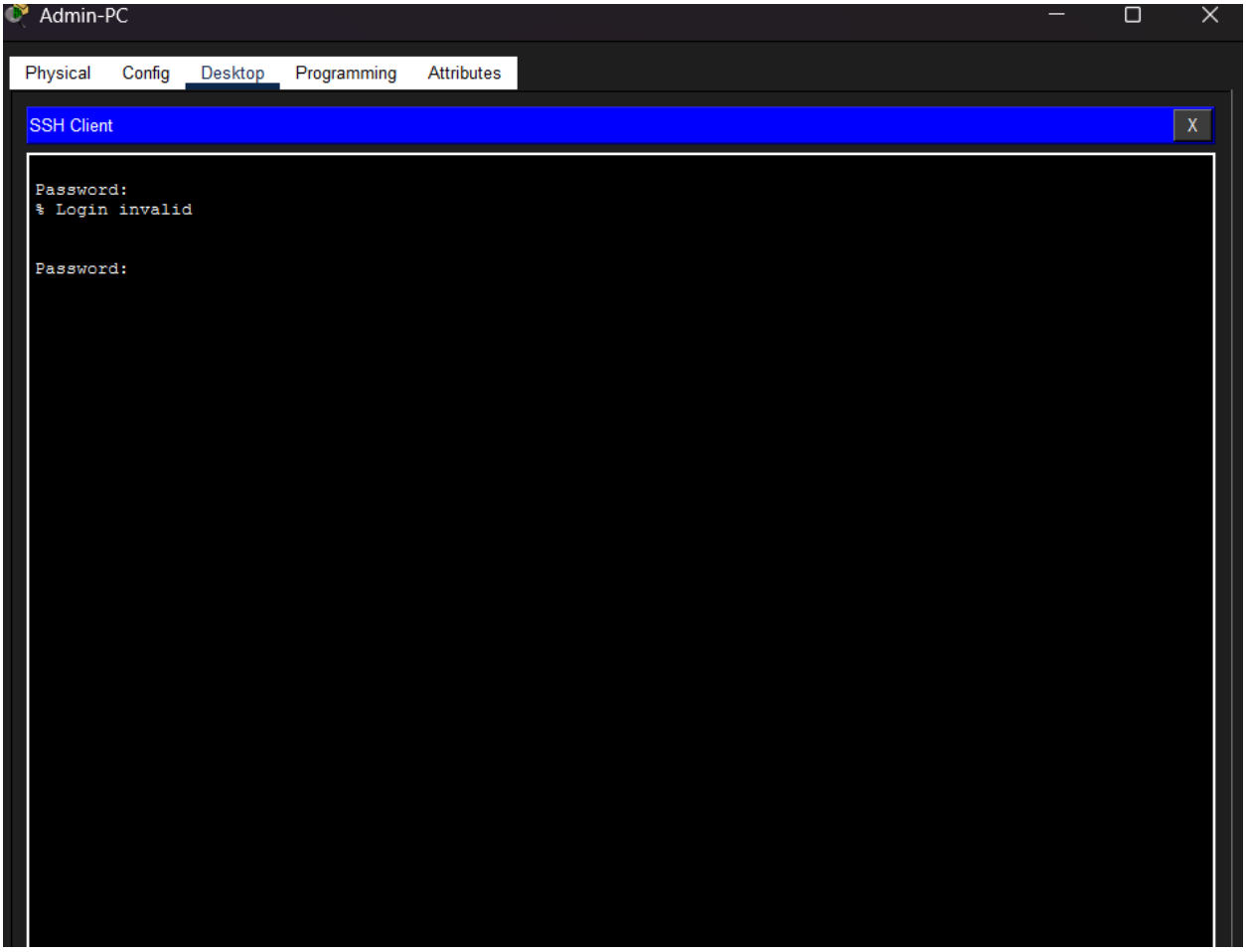


Figure 50: Login with incorrect password

Description: SSH connection using an incorrect password display "Login invalid". Indicates that the authentication process is in place.

Additional note for Section 9.8:

"Individual users can be created with encrypted passwords with local AAA authentication by using SSH in Packet Tracer ASA 5506-X emulation. However, privilege level assignment (privilege 15, privilege 5, privilege 1) cannot be done in this simulation. In real-time scenario with actual ASA devices, a different privilege level will be assigned to each user. The centralized AAA configuration with FreeRADIUS + LDAP will also be done."

9. CONCLUSION

Northbridge Savings & Finance is dealing with security issues because of ten years of growth without clear sections one way to sign in or a plan for keeping things safe. The recent attacks with ransomware in the money world and the trick someone tried on an employee have made security the main thing the people in charge are thinking about. This report. Showed 8 specific dangers that are important for Northbridges situation. Each one follows a path that starts with a thing you have a weak spot, then a danger then how it gets used then the attack, then what happens, then the risk. It suggested a plan with 26 ways to stop these dangers. The plan uses different ways by making some actions that help with many problems like C01 Segmentation (handles 5 dangers) and C11 Centralized Logging (handles all 8 dangers). The report looked at. Suggested new security tools: Cisco AnyConnect for safe internet access (has built-in ways to check who is using it and knows who is who) FreeRADIUS + LDAP for checking who is who (central no cost works with devices on the network) Zone Based Firewall for how the network is set up (many firewalls, easy to use, complete) and Suricata for watching for unsafe things (knows about known problems and also spots unusual things stops them as they happen and is free).

The report showed how to do this in life with 8 different setups using Cisco Packet Tracer. Each setup has the commands, ways to check it works and why it helps. It suggested a way to build a network with 9 areas and many firewalls, which directly fixes the problem of a network that lets bad things move around easily. The suggestions are easy to do, not too expensive and fit perfectly with what Northbridge needs. They offer protection and help set up for more advanced ways in the future like smaller sections and always checking who is using things. The next steps for Northbridge are to say yes to the plan and the money needed to do it focus on the parts that deal with risk (T1, T4, T6) start with making sections in the network (C01, C02) as the base put in a way to check who is who (C10) and a way to make sure people are who they say they are (C03) which helps with many dangers do training about security (C09) right away because the last trick shows it's important check the backups (C13) before the money part is ready and make a plan for what to do if something goes wrong (C14) which is missing right now.

Once these ways are in place Northbridge will be much better, at keeping customer information safe following the rules and keeping customers happy.

10. REFERENCES

1. NIST. (2018). *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*. https://www.nist.gov/cyberframework
2. NIST. (2020). *SP 800-207: Zero Trust Architecture*. https://csrc.nist.gov/publications/detail/sp/800-207/final
3. CISA. (2021). *Cyber Essentials Toolkit*. https://www.cisa.gov/cyber-essentials
4. Cisco Systems. (2024). *Cisco AnyConnect Secure Mobility Client*. https://www.cisco.com/c/en/us/products/security/anyconnect-secure-mobility-client/index.html
5. Cisco Systems. (2024). *Cisco Identity Services Engine (ISE)*. https://www.cisco.com/c/en/us/products/security/identity-services-engine/index.html
6. Cisco Systems. (2024). Cisco ASA 5506-X Series. https://www.cisco.com/c/en/us/products/security/asa-5500-series-next-generation-firewalls/index.html
7. OWASP. (2021). OWASP Top 10:2021. https://owasp.org/Top10/
8. Suricata. (2024). Suricata Open-Source IDS/IPS. https://suricata.io/
9. Snort. (2024). Snort - Network Intrusion Detection & Prevention System. https://www.snort.org/
10. Zeek. (2024). Zeek Network Security Monitor. https://zeek.org/
11. FreeRADIUS. (2024). FreeRADIUS - The World's Most Popular RADIUS Server. https://freeradius.org/
12. Keycloak. (2024). Keycloak — Open-Source Identity and Access Management. https://www.keycloak.org/

10.1 Generative AI Prompt Log

1. **Prompt 1:** "*Read this IE3122 Network Security assignment PDF and extract all mandatory deliverables, the marking scheme, and the required report structure. Create a checklist for the group.*"

2. **Prompt 2:** "*Generate 8 realistic threat models for Northbridge Savings & Finance following the exact chain: Asset → Vulnerability → Threat → Exploit → Attack → Impact → Risk. Base them on the scenario's weaknesses such as flat network, shared VPN account, and no MFA.*"

3. **Prompt 3:** "*Help me create a layered security plan with a master control list that minimizes the total number of controls. Include Control-to-Threat mapping, Function × Category table, and a written Control Minimization justification.*"

4. **Prompt 4:** "*Compare VPN, AAA, Network Architecture, and IDS/IPS options for a mid-sized bank. For each area, list multiple solutions and recommend one with justification tied to Northbridge's budget and weaknesses.*"

5. **Prompt 5:** "*Generate 8 Cisco Packet Tracer configurations for network hardening: VLAN segmentation, SSH, extended ACL, port security, inter-VLAN ACL, DHCP snooping, DAI, and AAA. Provide exact Cisco IOS commands and verification steps for each.*"

6. ***Prompt 7:*** "*Explain the Packet Tracer ASA 5506-X license limitation that blocks multi-zone traffic and suggest a valid workaround for a university assignment.*"

10.2 List of Abbreviations

Abbreviation	Full Form
AAA	Authentication, Authorization, Accounting
ACL	Access Control List
ARP	Address Resolution Protocol
BCP	Business Continuity Plan
BYOD	Bring Your Own Device
CIA	Confidentiality, Integrity, Availability
DAI	Dynamic ARP Inspection
DMZ	Demilitarized Zone
DR	Disaster Recovery
EDR	Endpoint Detection and Response
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IR	Incident Response
ISE	Identity Services Engine
LDAP	Lightweight Directory Access Protocol
MFA	Multi-Factor Authentication
NAC	Network Access Control
NGFW	Next-Generation Firewall
NPS	Network Policy Server
RADIUS	Remote Authentication Dial-In User Service
RBAC	Role-Based Access Control
SIEM	Security Information and Event Management
SQLi	SQL Injection
SSH	Secure Shell
SSO	Single Sign-On
STP	Spanning Tree Protocol
VLAN	Virtual Local Area Network
VPN	Virtual Private Network
WAF	Web Application Firewall
XSS	Cross-Site Scripting

11. APPENDICES - INDIVIDUAL TECHNOLOGY PROPOSALS

11.1 APPENDIX A — MEMBER 1 TECHNOLOGY PROPOSALS

11.1.1 VPN Proposal

Selected Technology: OpenVPN

OpenVPN should be used for the implementation of remote access in Northbridge. OpenVPN is a free and open-source SSL/TLS-based virtual private network protocol which employs very powerful encryption algorithms based on AES-256 cipher. It allows per-user certificate authentication and thus prevents the problem of a single shared user account, mentioned in the scenario. Every individual user and contractor will have his/her own certificate. This will give Northbridge a control over who logs in to the system and when. OpenVPN integrates easily with MFA solutions through plugins and hence satisfies the need for zero MFA capability at Northbridge. OpenVPN is inexpensive, because it is a free, open-source software. It supports remote access and site-to-site connections simultaneously; hence there is a single product that solves both problems. It works with existing infrastructure and does not require changing the whole ecosystem of vendor products. It can be implemented on ordinary server hardware and controlled by an IT department.

11.1.2 AAA Proposal

Selected Technology: Cisco ISE

Cisco Identity Services Engine (ISE) is proposed to be Northbridge's centralized AAA system. Cisco ISE will serve as a single source of truth for all AAA operations related to any network devices, applications, and users' accounts. This will solve the problem of each device and application having their own independent set of user accounts. Cisco ISE will work natively with Cisco switches, routers, and wireless controllers and will offer centralized policy enforcement for both head office and all six branches. Multi-factor authentication works natively with Cisco ISE and is crucial since currently Northbridge has no MFA at all. On the top of that, Cisco ISE has BYOD profiling and onboarding that allows identifying and controlling personal devices connecting to the network. Finally, accounting and logging capabilities will offer comprehensive audit trails of who accessed what and when that solves the problem of absence of centralized logging. Even though Cisco ISE will require some investment, it offers enterprise-level security suitable for a financial institution.

11.1.3 Secure Network Architecture

Selected Technology: Zone-Based Firewall Architecture

A zone-based firewall architecture is proposed for Northbridge. This zone-based firewall architecture design divides the network into distinct security zones, each protected by firewalls with controlled traffic between them. The zones include an Internet zone, a DMZ for facing services such as the online banking portal and mail relay, a User zone for staff workstations a Server zone for core banking and email a Database zone for the customer database and backups a Management zone for administrative access a Branch zone for the six branch offices and a Third-Party zone for payment processing partners. Multiple firewalls are placed at zone boundaries: a firewall between the Internet and DMZ an internal firewall between the DMZ and internal zones and a database firewall between the server zone and database zone. A zone-based firewall architecture directly addresses the network weakness described in the scenario where guest Wi-Fi, branch systems and the core banking environment all sit within reach of one another. Even if an attacker breaches the DMZ the attacker cannot directly reach the database because the internal firewall blocks movement. Branch offices connect through VPN to a branch zone, with restricted access. Payment partners are isolated in their zone and can only reach specific APIs, not internal systems. A zone-based firewall architecture is practical proven in services and can be implemented incrementally without disrupting daily operations.

11.1.4 IDS/IPS Proposal

Selected Technology: Snort

Snort is recommended as the chosen solution for the purpose of intrusion detection and prevention of Northbridge. Snort is an open-source IDS/IPS solution that uses a signature-based technique to detect and prevent already known types of attacks such as ransomware, SQL injection, cross-site scripting, and phishing. This solution can be used inline in order to block the traffic containing malicious code not only to provide alerts. This solves the problem described in the scenario regarding the lack of intrusion detection and prevention capabilities within the organization that allows potential attackers to perform reconnaissance and active attacks unnoticed. The solution possesses a huge community of active users who develop updated signatures for this IDS on a regular basis that is crucial for any financial company due to constantly appearing attack techniques. This solution can be applied in various points of the network perimeter, internal network zones, and in the database zone according to the zone-based firewall architecture. The solution is free and open-source and therefore it is suitable for Northbridge's tight budget.

11.2 APPENDIX B — MEMBER 2 TECHNOLOGY PROPOSALS

11.2.1 VPN Proposal

Selected Technology: WireGuard

WireGuard should be implemented for remote access and connectivity of Northbridge branches. WireGuard is an innovative and open-source technology that employs cutting-edge cryptography based on such technologies as ChaCha20 encryption and Poly1305 authentication. The fact that WireGuard operates on the kernel level results in much better performance compared to other technologies that rely on SSL/TLS, thus allowing for greater throughput and reduced latency of Northbridge's six branches that have daily banking traffic sent to the head office. WireGuard has simplified and efficient configuration compared to such technologies as IPsec and OpenVPN and allows the small IT department of Northbridge to work more effectively. WireGuard employs per-user cryptographic keys; therefore, it allows for individual accountability and solves the problem of using shared accounts for access to a VPN network. Each remote employee and each contractor has their own cryptographic keys, and all accesses are logged with information about the corresponding user. WireGuard is free and open-source software without licensing fees, thus fitting Northbridge's budget. The software is easy to audit for any security flaws due to the small size of its codebase. Although WireGuard lacks MFA functionality, there are several ways to integrate this capability that make it a viable high-performance solution for Northbridge.

11.2.2 AAA Proposal

Selected Technology: FreeRADIUS + LDAP

The recommended AAA solution for Northbridge consists of FreeRADIUS in combination with LDAP. FreeRADIUS is the most popular RADIUS server implementation in the world and allows for performing authentication, authorization and accounting on the network devices from all the vendors including Cisco, Juniper and others. LDAP is a directory service that will serve as a central user directory instead of local accounts that are maintained on each device and application today. This solves the weakness related to separate account sets being managed by each device and application, thus causing poor identity management and password reuse. FreeRADIUS can implement multi-factor authentication using modules like Google Authenticator or Duo. RADIUS accounting will provide the detailed access log indicating who accessed what resources, when and from where, solving the problem of the lack of centralized logs. The solution is free and open source, therefore not requiring the expensive licensing fees that are important for the budget of Northbridge. The solution is very flexible and can be integrated with existing infrastructure and future developments without vendor lock-in. It

scales well from 450 employees to several thousand without the major changes in architecture. It is well documented and supported by a large community.

Secure Network Architecture Proposal

Selected Technology: DMZ + Dual-Firewall Architecture

I propose a DMZ with dual-firewall layout for Northbridge. This plan puts services that people use, such as the online banking portal, the mobile app backend and the mail relay into a DMZ that is separated from the internal network. Two firewalls protect the network: one on the outside between the Internet and the DMZ and one on the inside between the DMZ and the internal network. The outside firewall allows necessary inbound traffic, such as HTTPS to the web server and SMTP to the mail relay and blocks all other inbound traffic. The inside firewall stops any traffic from the DMZ from reaching the systems so even if the web server is compromised an attacker cannot move into the core banking environment. The core banking database and all customer data sit behind the firewall completely unreachable from the DMZ. This architecture directly tackles the threat to the online banking portal. The lack of a dedicated firewall described in the scenario. It is a known design that many banks use. It is easier to set up and maintain than complex zone-based or zero-trust architectures making it practical, for Northbridge's small IT team. As Northbridge's security maturity grows additional internal zones can be added behind the firewall.

11.2.3 IDS/IPS Proposal

Selected Technology: Suricata

Suricata is proposed as the solution for intrusion detection and prevention at Northbridge. Suricata is a source IDS/IPS that offers both signature-based detection and anomaly-based detection giving Northbridge a wider safety net than solutions that rely only on signatures. Anomaly detection is very important because Northbridge does not yet have a pattern of network activity; insider threats or new attacks may not match existing signatures. Suricata can spot patterns such as large data moves from the customer database or strange outbound connections that could show data theft. Suricata is multi-threaded and fast able to manage Northbridge traffic for 450 staff at seven sites without slowdowns. Suricata writes logs in EVE JSON format, which can be fed straight into a central SIEM solving the missing centralized logging problem mentioned in the scenario. Suricata can be set up inline to stop traffic in real time giving both detection and prevention. Suricata is open source with an active community that keeps rules updated. Suricata supports the zone-based design by letting sensors sit at places, in the network. For a bank that wants both sight and defense Suricata offers the mix of power and affordability.

11.3 APPENDIX C — MEMBER 3 TECHNOLOGY PROPOSALS

11.3.1 VPN Proposal

Selected Technology: Cisco AnyConnect

The recommended solution for Northbridge's secure remote access would be Cisco AnyConnect. Cisco AnyConnect is an enterprise SSL VPN client from Cisco which allows MFA support including SAML, Duo and RSA Tokens. This is important because currently, Northbridge does not have MFA in its organization. AnyConnect offers centralized management through Cisco ASA or Firepower. This means that Northbridge's IT staff can centrally manage their remote access from one management console. Per user authentication with logging on what user logged in, when and from where, which helps solving the problem of sharing account among users. It offers always-on VPN service which ensures that remote devices have a secure tunnel to the internet whenever the device is connected to the internet. It offers remote access as well as site-to-site remote access capabilities for branch offices. AnyConnect can be integrated into Cisco network devices which Northbridge could use for branch offices either Northbridge has bought before or going to buy soon. AnyConnect is commonly used by financial organizations. Thus, using this product helps in complying with regulations. Although AnyConnect needs licenses, it offers enterprise-grade secure remote access with MFA.

11.3.2 AAA Proposal

Selected Technology: Windows Network Policy Server (NPS)

Windows Network Policy Server (NPS) is proposed as Northbridges AAA solution. NPS is Microsoft’s implementation of RADIUS. It integrates natively with Active Directory. Most organizations, including Northbridge likely already use Active Directory for user management. This means Northbridge can use its existing user accounts and group policies. There is no need to build an identity store. NPS provides authentication for VPN connections. It also supports access. It handles network device management. NPS replaces the accounts on every device and application. This directly addresses the identity management described in the scenario. NPS supports multi-factor authentication. It does this through Azure MFA integration. This gives Northbridge a path to implement MFA across the organization. NPS provides accounting logs. These logs record who authenticated, when they authenticated and what they accessed. This addresses the lack of logging and audit trails. If Northbridge already has Windows Server licensing NPS is essentially free to deploy. Windows-based management is familiar to IT staff. This reduces training requirements. NPS supports RADIUS. This means network devices, from Cisco and other vendors can authenticate against it. It scales well for Northbridges size. It can also be extended as the organization grows.

11.3.3 Secure Network Architecture Proposal

Selected Technology: Micro-Segmentation Architecture

A micro-segmentation architecture is suggested for Northbridge. Micro-segmentation brings network segmentation to a more detailed level by making security zones around single workloads, applications or groups of connected systems instead of just at the edge of the network. For Northbridge this means the main banking application, the customer database, the email system and the online banking portal would each be in their micro-segment with special firewall rules that manage the traffic between them. Inside the data centre no system can talk to another unless it is allowed. This directly solves the problem found in the scenario where guest Wi-Fi, branch systems and the main banking arrear's all close to each other. With micro-segmentation even if someone breaks into one part they can't move to areas because all connections between parts are stopped by default. The customer database would be the limited micro-segment only open to the main banking application on certain ports. Branch offices would join their micro-segment and only have access to the services they need. Payment partners would be in their micro-segment which helps deal with the risk, from outside companies. Micro-segmentation gives the control that a financial company needs when handling private customer information. It works well as Northbridge grows. Can be put in place step by step starting with the most important systems.

11.3.4 IDS/IPS Proposal

Selected Technology: Cisco Firepower

The intrusion detection and prevention system recommended for Northbridge is the Cisco Firepower. The Firepower is the next generation Cisco IPS system that uses signature based detection, anomaly detection, and reputation filtering to identify both known and unknown threats. Its ability to integrate with Cisco network devices and manage security events using the Firepower Management Center solves the issue highlighted by the findings of lack of a centralized logging or auditing capability. The ability of the Cisco Firepower to detect and block threats in real time alleviates the workload of the IT staff at Northbridge by preventing common attacks without any need of intervention. The visibility provided by the system in network traffic, application usage, and behavior of users is crucial in detecting any potential insider threat or compromised accounts. The product is extensively used in the financial services industry; therefore, its use by Northbridge gives confidence on compliance with regulations. Even though the product requires licensing and hardware purchase costs, it offers enterprise-class security with central management that will suit Northbridge.

11.4 APPENDIX D — MEMBER 4 TECHNOLOGY PROPOSALS

11.4.1 VPN Proposal

Selected Technology: IPsec Site-to-Site VPN

IPsec site-to-site VPN is proposed to be deployed in Northbridge for connecting its branch offices and for providing remote access. The suite of IPsec protocols represents a well-developed standard that is known to provide high levels of encryption and authentication of VPN tunnels. Northbridge has six branch offices which connect to the head office via dedicated links. IPsec site-to-site VPN will provide encrypted tunnels protecting all traffic sent between branches and head office. Being included into the Cisco IOS, IPsec requires nothing more than already installed on the branches of Northbridge Cisco routers. There are no licensing expenses involved, which is quite significant for Northbridge due to its budget limitations. IPsec can use AES-256 encryption, which is the current industry standard of encryption used by the financial institutions. IPsec can provide remote access via IPsec client software, but this function is less popular for individual users than SSL VPN. However, IPsec is compatible with all vendors of network equipment and it is mature and proven technology. For branch connectivity IPsec site-to-site VPN is the most efficient solution.

11.4.2 AAA Proposal

Selected Technology: Keycloak

Keycloak would be Northbridge's proposed AAA service for its applications and users' identity management. Keycloak is an open-source IAM software providing SSO, MFA, and centralized user management. Northbridge has several applications such as its core banking application, online banking portal, mobile app backend, and email. Keycloak will allow Northbridge's staff to log in once and gain access to authorized applications with one login, enhancing security and usability. It natively supports MFA such as TOTP and WebAuthn, addressing Northbridge's deficiency in MFA. The software will replace the local accounts in each application with a centralized user directory, solving the problem of having separate account directories in each application. It is compatible with modern identity standards such as SAML, OAuth2, and OpenID Connect, allowing it to integrate with current and future applications. The software is free and open source, eliminating any licensing costs associated with it. It also offers detailed authentication and authorization logs, which may then be sent to the central logging service. Although Keycloak is primarily an application level IAM software, it can be integrated with authentication on network devices through RADIUS bridging.

11.4.3 Secure Network Architecture Proposal

Selected Technology: Zero-Trust Architecture

A zero-trust architecture is being considered for Northbridge. Zero-trust removes the idea of a trusted network and an untrusted external network. Instead every single access request is. Approved no matter where it comes from. The main idea is to never trust anything and always check. For Northbridge this means that even people working inside the office network need to be checked and given permission before they can use the core banking database or look at customer information. Every link between systems needs to be allowed by rules and all the data moving around is encrypted and checked. This solves the problem that the network is not divided into sections and that the bank cannot tell who is using the systems from outside. Zero-trust also helps stop problems from inside because even workers who have the right to use some systems need to show they are who they say they are each time. Third-party payment partners would get access based on their identity to certain APIs and not to other parts of the system. Offices that are not the one would be treated as not trusted until they are checked and approved. Zero-trust is what the security world is focusing on now and putting it in place helps Northbridge get ready for what's coming. It can be added step by step starting with the important parts, like the customer database.

11.4.4 IDS/IPS Proposal

Selected Technology: Zeek

Zeek, which used to be called Bro is being suggested as Northbridges network security monitoring solution. Zeek is an open-source network analysis framework that gives insight into network traffic creating detailed logs of connections DNS queries, HTTP requests, SSL certificates and other information. Unlike tools that look for known attack patterns Zeek tries to understand what is taking place on the network. This is important for finding threats that do not match any known patterns. This directly solves the problem that Northbridge has no way to detect any kind of intrusion or prevent it anywhere on the network. This leaves the bank unable to see any attempts to gather information or any active attacks. Zeek can find behavior such as big data transfers from the customer database, strange outgoing connections or unexpected use of protocols that could mean an insider threat or a system that has been taken over. It creates logs that can be sent to a central SIEM system solving the problem of no central logging or records of activity. Its scripting language lets Northbridge create custom rules for detecting threats that fit its environment and the kinds of threats it faces. Zeek is open-source and has a strong community, behind it. Even though Zeek does not stop traffic directly it gives the visibility needed to understand attacks. It can work with an IPS system to provide coverage for both detecting and stopping threats.